

KALI LINUX

AI, Security Testing & Digital Forensics

*A Beginner-Friendly Practical Manual for Understanding
When, Why, and How to Use Essential Tools*

Prepared by Alberto (AI) Leiva

Final English Edition v1.0 - July 2026

Reviewed for Kali Linux 2026.2

English Master Edition

FREE EDUCATIONAL RESOURCE

An independent guide. Not sponsored, endorsed, or officially affiliated with Kali Linux, OffSec, or Hack The Box.

Preface

Passing Knowledge Forward

I created this manual because I wanted beginners to have the kind of guide I would have valued when I first entered the technology and cybersecurity field. Powerful tools are easier to find than patient explanations. My goal is to explain not only what a tool does, but why it matters, when it should be used, and what responsibilities come with using it.

After many years in the industry, I believe experience has the greatest value when it is shared. Technology changes constantly, but the need for curiosity, discipline, ethics, and sound judgment does not. This book is my way of passing those lessons forward to students, career changers, and young people who may one day protect systems and information that the rest of us depend on.

I also understand that learning does not look the same for everyone. I have dysgraphia, a learning disability that can make writing, spelling, and organizing written information difficult. The ideas and experience were mine, but turning them into a clear, structured book would have been extremely difficult for me without the support of an AI writing and editing assistant.

That assistance did not replace professional experience, judgment, or responsibility. It helped me organize my thoughts, improve the language, check consistency, and present the material in a form that other people can use. Every technology should be approached in the same way: as a tool that can extend human ability when it is used carefully, honestly, and responsibly.

This manual is offered freely because opportunity should not depend entirely on a person's income, location, language, or learning differences. I hope it gives someone the confidence to begin, the patience to keep learning, and a lifelong interest in the changing and challenging world of cybersecurity, artificial intelligence, and digital forensics.

Most of all, I hope readers remember that technical skill is only part of becoming a security professional. Character, permission, respect for others, and the willingness to use knowledge for good are just as important.

— *Alberto (AI) Leiva*

About this manual

This manual was created to help beginners take their first steps into Kali Linux, artificial intelligence tools, ethical hacking, security testing, and digital forensics. You do not need to be an expert to begin. You need curiosity, patience, and a willingness to learn responsibly.

Cybersecurity is constantly changing. New technologies appear, new vulnerabilities are discovered, and new defenses are developed every day. That is part of what makes this field challenging, but it is also what makes it exciting. The purpose of this free manual is not simply to teach commands. It is to help readers understand why a tool is used, when it should be used, what the results mean, and what responsibilities come with technical skill.

The rule that guides every chapter

Technical ability does not create permission. Ethical hacking requires clear authorization, a defined scope, care for other people's information, and honest reporting.

License

Unless a section states otherwise, the original text in this manual is shared under the Creative Commons Attribution-Noncommercial-Share Alike 4.0 International license (CC BY-NC-SA 4.0). You may share and

adapt the material for noncommercial purposes when you provide attribution and distribute adaptations under the same license. Third-party names, trademarks, screenshots, documentation, and code remain the property of their respective owners.

[Creative Commons CC BY-NC-SA 4.0](https://creativecommons.org/licenses/by-nc-sa/4.0/)

Important disclaimer

This publication is educational and is not legal advice. Laws differ by country and circumstances. Perform exercises only in authorized labs or on systems you own and control. The author and contributors do not authorize or encourage unauthorized access, disruption, credential theft, privacy violations, or other harmful activity.

How to use this first edition

- Read the ethics and lab-safety chapters before using security tools.
- Start with a virtual machine unless you have a strong reason to install Kali directly on hardware.
- Use Hack The Box Starting Point or your own intentionally vulnerable lab for practice.
- Type commands yourself and understand the target before pressing Enter.
- Keep notes. Every practical chapter includes an interpretation-and-reporting mindset.
- Check official documentation because Kali and its tools change frequently.

Index and Table of Contents

Preface.....	2
Passing Knowledge Forward	2
About this manual.....	2
License	2
Important disclaimer	3
How to use this first edition.....	3
Index and Table of Contents	3
1. AI Security Foundations, Careers, and Professional Skills	7
1.1 AI Security Foundations and Career Skills	7
1.2 Semgrep for secure AI application code	7
1.3 Continue for AI-assisted development	8
1.4 Hugging Face.....	8
1.5 A beginner AI red-team workflow	8
2. Learning Roadmap, Ethics, and Responsible Practice	9
2.1 How to use this manual and learning roadmap	9
2.2 Ethical Hacking, Authorization, and Consequences.....	9
3. Choosing and Installing Kali Linux	11
3.1 Which image should a beginner choose?	11
3.2 Recommended hardware	11
3.3 VMware on Windows - recommended for many beginners	12

3.4 Practical checklist	12
3.5 Hyper-V on Windows 11 Pro	12
3.6 Practical checklist	12
3.7 VirtualBox.....	13
3.8 Practical checklist	13
3.9 Separate partition and dual boot.....	13
3.10 Practical checklist	13
3.11 Mac computers.....	13
3.12 Practical checklist	13
3.13 First boot, updates, and safe defaults	14
3.14 Essential Linux commands	14
3.15 Detailed Installation Walkthroughs	14
3.16 Before you download anything	14
3.17 Choose the correct Kali image	15
3.18 VMware Workstation on Windows - easiest choice for many beginners.....	15
3.19 Hyper-V on Windows 11 Pro, Enterprise, or Education	15
3.20 Oracle VirtualBox on Windows, Linux, or Intel Mac.....	16
3.21 Kali on Apple Silicon Mac - M1, M2, M3, and newer	16
3.22 Intel-based Mac	17
3.23 Separate partition or dual boot with Windows.....	17
3.24 Dedicated computer installation.....	18
3.25 First boot checklist for every installation	18
3.26 Virtualization links at a glance.....	18
4. Building a Safe Practice Lab.....	20
4.1 Hack The Box as the primary practice area	20
4.2 Safe HTB workflow	20
5. AI Tools for Cybersecurity Learning	22
5.1 Ollama	22
5.2 Open WebUI	23
5.3 Promptfoo	24
5.4 Giskard.....	25
5.5 LangChain	26
5.6 LlamaIndex.....	27
5.7 Aider	27
5.8 Open Interpreter	28
6. MCP, RAG, and AI Agents	30
6.1 RAG in plain language	30
6.2 Vector databases in plain language.....	30
6.3 Agents and tool use.....	30

6.4 Model Context Protocol (MCP): a core AI security principle	30
6.5 Why MCP matters to employers	30
6.6 The security principles behind MCP	31
6.7 A beginner MCP review checklist	31
6.8 AI agents: the basic idea	31
6.9 The risks every employer should understand	31
6.10 Microsoft Azure and Microsoft Foundry: security basics	31
6.11 AWS and Amazon Bedrock: security basics	32
6.12 OpenAI API and ChatGPT-connected workflows: security basics	32
6.13 A minimum employer checklist for AI agents	32
6.14 Official starting references	32
6.15 A simple AI security checklist	33
7. GRC and AI Governance	34
7.1 Governance	34
7.2 Risk	34
7.3 Compliance	34
7.4 Important beginner documents	34
7.5 AI governance questions	35
7.6 Frameworks to recognize	35
8. Essential Kali Security Tools	36
8.1 Choosing the right Kali tool	36
8.2 Twenty Essential Kali Security Tools	36
8.3 Nmap	36
8.4 Wireshark	37
8.5 Burp Suite Community Edition	38
8.6 Metasploit Framework	39
8.7 Gobuster	40
8.8 FFUF	40
8.9 Nikto	41
8.10 sqlmap	42
8.11 OWASP ZAP	43
8.12 Hydra	43
8.13 John the Ripper	44
8.14 Hashcat	45
8.15 Aircrack-ng	46
8.16 Bettercap	46
8.17 Responder	47
8.18 NetExec	48
8.19 enum4linux-ng	49

8.20 Searchsploit	49
8.21 Autopsy	50
8.22 Maltego	51
9. Digital Forensics Fundamentals and Tools.....	53
9.1 Digital Forensics Fundamentals	53
9.2 Sleuth Kit.....	53
9.3 Guymager.....	54
9.4 ExifTool	55
9.5 Binwalk	56
9.6 Volatility 3.....	57
9.7 Foremost.....	58
9.8 bulk_extractor.....	59
9.9 Plaso/log2timeline	60
9.10 YARA	60
9.11 Ghidra	61
10. Reporting What You Learn.....	62
10.1 Simple finding template.....	62
10.2 Avoid these reporting mistakes	63
11. Your First 30 Days with Kali Linux.....	64
11.1 Week 1 - Build safe foundations	64
11.2 Week 2 - Learn to observe.....	64
11.3 Week 3 - Begin web and HTB practice.....	64
11.4 Week 4 - Connect the skills.....	64
12. English for Technology Careers	65
12.1 Where English appears.....	65
12.2 A realistic goal	65
12.3 Free English Learning Resources Available Worldwide	65
12.4 A simple weekly English plan	65
13. Career Paths and Continued Learning	67
Lab folder pattern.....	67
Verification notes for this edition	Error! Bookmark not defined.
Planned GitHub repository structure	70

1. AI Security Foundations, Careers, and Professional Skills

1.1 AI Security Foundations and Career Skills

AI security is more than using a chatbot. It combines software security, data protection, model testing, governance, privacy, and clear communication. This section shows where the jobs are developing and what a beginner can learn first.

Why AI security is a growing career area

Organizations are integrating generative AI, copilots, retrieval systems, and automated agents into their business processes. These systems create new questions: What data can the model see? Can a user manipulate its instructions? Can the model call tools it should not use? Can sensitive information appear in an answer? AI security professionals help answer those questions before a system causes harm.

1. AI security analyst - reviews risks, tests safeguards, and documents findings.
2. AI governance analyst - helps create policies, inventories, approvals, and evidence.
3. LLM security tester or AI red-team tester - evaluates prompt injection, data leakage, unsafe tool use, and other failure modes.
4. Secure AI engineer - adds authentication, authorization, filtering, logging, and monitoring to AI applications.
5. RAG security specialist - protects document retrieval, vector databases, source permissions, and citations.
6. AI risk and compliance specialist - connects technical controls to NIST, ISO, privacy, and contractual requirements.
7. AI incident-response analyst - investigates misuse, leaked data, harmful outputs, and compromised AI workflows.

A beginner does not need to master every role. Start with Linux, networking, Python basics, safe testing, and the ability to explain a finding clearly.

1.2 Semgrep for secure AI application code

What it is and why to use it

Semgrep is a source-code scanning tool. It searches code for patterns that may indicate security mistakes, such as hard-coded secrets, unsafe input handling, or insecure API use. It is valuable for AI applications because many AI failures stem from the surrounding code rather than the model itself.

When to use it

- ✓ Reviewing your own Python or JavaScript AI project.
- ✓ Checking whether API keys were accidentally placed in source code.
- ✓ Finding risky functions before a code review.

Install and check

Use a Python virtual environment when possible. Then install Semgrep with pip and confirm it starts with `semgrep --version`. Kali may also provide a packaged version, but the official documentation should be checked for the current method.

First safe exercise

1. **Create a small practice file that contains a fake test password.**
2. **Run Semgrep only against that local practice folder.**
3. **Read the rule name and file location.**
4. **Remove the fake password and run the scan again.**

5. Write one sentence explaining why secrets should be stored outside source code.

[Official Semgrep documentation](#)

1.3 Continue for AI-assisted development

Continue is an AI coding assistant that can work inside supported development environments. It can explain code, suggest changes, and connect to local or hosted models. Use it as a helper, not as an authority. Every suggested change must be reviewed and tested.

Beginner safety rules

- ✓ Use a practice repository, not a production system.
- ✓ Do not send private client code to a public model without approval.
- ✓ Review the exact files and commands the assistant proposes.
- ✓ Use Git so unwanted changes can be reversed.

[Official Continue documentation](#)

1.4 Hugging Face

Hugging Face is a large ecosystem for models, datasets, demonstrations, and development libraries. It helps learners understand that models have licenses, intended uses, limitations, file sizes, and security considerations. A model page should be read before a model is downloaded or used.

What a beginner should check

- ✓ The model license and allowed uses.
- ✓ The model card and known limitations.
- ✓ Whether code must be trusted or executed.
- ✓ The download size and hardware requirements.
- ✓ Whether the repository is maintained by a recognized organization or an unknown account.

[Hugging Face documentation](#)

1.5 A beginner AI red-team workflow

AI red teaming means testing an AI system for harmful or unexpected behavior with permission. It is not an excuse to attack a public chatbot or bypass another organization's controls.

1. **Write down the authorized application, users, data, model, and test period.**
2. **List the behaviors that must be protected, such as confidential data, system instructions, and tool permissions.**
3. **Create normal test prompts first so you understand expected behavior.**
4. **Test one risk category at a time, such as prompt injection or unsafe tool use.**
5. **Save the prompt, response, model version, settings, and time.**
6. **Repeat the test to determine whether the behavior is consistent.**
7. **Explain the impact without exaggeration.**
8. **Recommend a control and retest after the control is applied.**

[OWASP GenAI Security Project](#)

[MITRE ATLAS](#)

[NIST AI Risk Management Framework](#)

2. Learning Roadmap, Ethics, and Responsible Practice

2.1 How to use this manual and learning roadmap

Section	What you will learn
Part I	Ethics, consequences, and the professional mindset
Part II	Choosing, installing, and maintaining Kali Linux
Part III	Building a safe practice lab and using Hack The Box
Part IV	AI tools for learning, testing, and analysis
Part V	Twenty essential Kali security tools
Part VI	Digital forensics fundamentals and tools
Part VII	Reporting, career paths, and your first 30 days
Appendices	Checklists, glossary, official links, and source notes

Suggested learning order

1. **Read Parts I-III before running tools.**
2. **Install Kali in a virtual machine and create a clean snapshot.**
3. **Learn basic Linux navigation and networking.**
4. **Use the AI section to support understanding, not to replace it.**
5. **Practice reconnaissance and traffic analysis before exploitation.**
6. **Complete the forensics section using sample evidence, never original evidence.**
7. **Write a short report after every lab.**

2.2 Ethical Hacking, Authorization, and Consequences

Ethical hacking is the authorized use of security methods to identify weaknesses and help improve defenses. The same command can be ethical in a lab and unlawful on an unapproved system. The difference is permission, scope, purpose, and conduct.

Permission is specific, not assumed

Permission should identify the systems, dates, allowed techniques, contacts, and stop conditions. Permission to use a website is not permission to test it. Employment at an organization is not automatically permission to scan its network. A friend saying “try my Wi-Fi” may not be enough if the router, service, or data is someone else's.

Scope keeps good intentions from causing harm

Scope defines the boundaries of a test. It may include specific IP addresses, applications, accounts, hours, and prohibited actions. If a result points to a system outside the scope, stop and ask. Do not follow the trail simply because it is technically possible.

Consequences of unauthorized behavior

Unauthorized security activity can cause account suspension, school discipline, job loss, civil claims, criminal investigation, financial damage, loss of certifications, and long-term reputational harm. It can also hurt innocent people by exposing private messages, medical records, photographs, financial data, or business operations.

Responsible behavior when you discover a problem

Do not download more information than needed to demonstrate the issue. Do not publicly identify affected people. Record the minimum evidence necessary, protect it, and report through the organization's published security channel or an appropriate responsible-disclosure process.

Stop conditions

Stop immediately if you reach personal data, obtain unexpected administrative access, cause instability, identify the wrong target, lose authorization, or become unsure whether the next action is permitted.

Practice scenarios

Scenario	Professional response
A student scans the school network to “see what is open.”	Not ethical without explicit authorization. Curiosity does not replace permission.
A learner scans a Hack The Box machine assigned to their account.	Appropriate when the action follows the lab rules and stays within the assigned target.
A friend gives a Wi-Fi password and asks for a security check.	Pause. Clarify ownership, written permission, allowed actions, and whether other users or provider equipment may be affected.
A researcher finds a public login page and tries common passwords.	Unauthorized credential testing. Public access does not permit password attacks.
A learner analyzes a downloadable forensic practice image.	Appropriate when the evidence was provided for training and is handled according to the exercise instructions.

3. Choosing and Installing Kali Linux

Choosing and Installing Kali Linux

Kali Linux is a specialized Linux distribution for penetration testing, security assessment, digital forensics, and related work. It contains many powerful tools, but it is still a Linux operating system. Beginners should first learn safe installation, updates, files, users, permissions, networking, and recovery.

Current version note

This first edition was reviewed against the official Kali Linux 2026.2 point release available in July 2026. Kali is rolling, and its official point-release images are refreshed quarterly. Always verify the current release on the official download page.

[Official Kali Linux downloads](#)

[Official Kali Linux documentation](#)

3.1 Which image should a beginner choose?

- ✓ Windows or Linux computer with Intel/AMD processor: use the official x86_64/AMD64 point-release image.
- ✓ Apple Silicon Mac: use an ARM64 image designed for Apple Silicon virtualization.
- ✓ VMware, VirtualBox, or Hyper-V: prefer an official prebuilt virtual-machine image when available.
- ✓ Direct installation or dual boot: use the official Installer image, not an unofficial repackaged ISO.
- ✓ Avoid weekly images as a first choice unless you specifically need a recent fix and understand that they receive less point-release testing.

3.2 Recommended hardware

The diagrams in this manual are instructional. Each one summarizes the surrounding text so that a beginner can see the relationship between choices, systems, and security controls before reading the details.

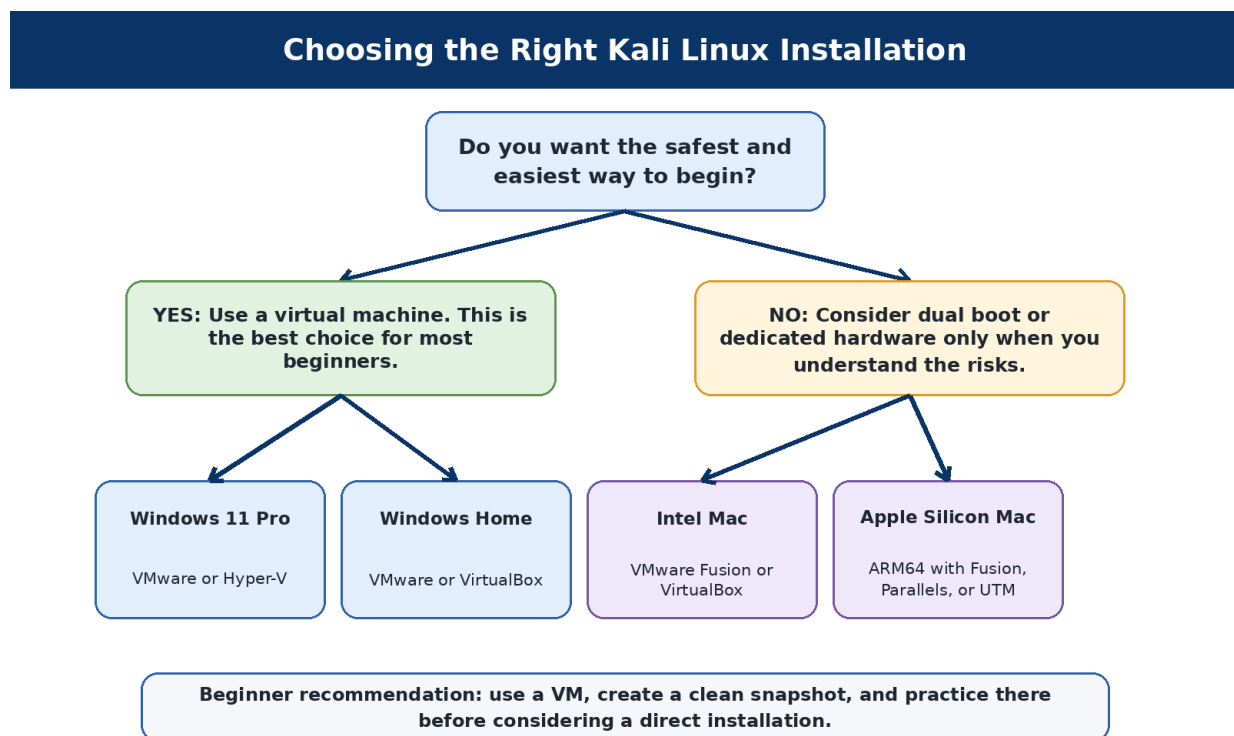


Figure 1. A beginner-friendly guide to choosing a Kali installation method.

Use	Reasonable starting point	Comfortable recommendation
-----	---------------------------	----------------------------

Use	Reasonable starting point	Comfortable recommendation
Basic Kali VM	2 CPU cores, 4 GB RAM, 60 GB disk	4 CPU cores, 8 GB RAM, 80-100 GB disk
Kali plus local AI	4 CPU cores, 8-12 GB RAM, 100 GB disk	6-8 CPU cores, 16 GB RAM, 150 GB disk
Forensics practice	4 CPU cores, 8 GB RAM, 120 GB disk	6 CPU cores, 16 GB RAM, separate evidence storage

Low-resource path

A learner with limited hardware can use a smaller Kali VM for basic tools and use Hack The Box Pwnbox for browser-based lab access. Local large language models may be impractical on older machines; cloud AI tools can be used with privacy precautions.

3.3 VMware on Windows - recommended for many beginners

VMware provides strong desktop integration, snapshots, and straightforward USB-device handling. Download the official prebuilt Kali VMware image when possible.

Confirm that virtualization is enabled in the computer firmware. Install VMware Workstation, download the official Kali VMware archive, verify the download, extract it, open the virtual machine, and change the default password.

Begin with NAT networking. NAT allows Kali to reach the Internet through the host while reducing accidental exposure to the local network. Use bridged mode only when the lab requires it and you understand the effect.

3.4 Practical checklist

- Create a snapshot named Clean Install before adding tools.
- Do not store VPN files or secrets in a public shared folder.
- Use host-only networking for isolated multi-VM labs.

Beginner recommendation

Use a virtual machine, create a clean snapshot, and practice there before considering a direct installation.

3.5 Hyper-V on Windows 11 Pro

Kali now provides an official prebuilt Hyper-V image. Extract the official archive and run its installation script with administrative approval, or create a Generation 2 VM from the installer ISO.

Hyper-V Enhanced Session Mode can provide clipboard and file-sharing features. USB passthrough is less direct than in some desktop hypervisors, which matters for wireless adapters and certain forensic devices.

3.6 Practical checklist

1. Use the official prebuilt Hyper-V image for the simplest setup.
2. Keep the virtual disk in a location with enough free space.
3. Create a checkpoint after the first update.

Beginner recommendation

Use a virtual machine, create a clean snapshot, and practice there before considering a direct installation.

3.7 VirtualBox

VirtualBox is widely available and works well for isolated practice labs. Kali provides both installation guidance and prebuilt VirtualBox images.

Import the official appliance or create a VM from the installer. Install guest additions if needed, and use snapshots before major tool or configuration changes.

3.8 Practical checklist

For safer lab work, disable the shared clipboard and shared folders when handling untrusted samples. Use NAT for normal learning and host-only networking for isolated local labs.

Beginner recommendation

Use a virtual machine, create a clean snapshot, and practice there before considering a direct installation.

3.9 Separate partition and dual boot

Dual boot provides direct hardware access and better performance, but it is riskier for beginners because partitioning and bootloader mistakes can make the existing operating system unavailable.

Back up important files, save the BitLocker recovery key, disable Fast Startup, shrink the Windows partition from Windows Disk Management, and leave the new space unallocated. Boot the official Kali installer in the same UEFI mode as Windows.

Never select an entire-disk option if you intend to keep the existing operating system. Read every partitioning screen slowly.

3.10 Practical checklist

- ✓ Use a VM first unless direct hardware access is genuinely required.
- ✓ Keep recovery media available.
- ✓ Do not repartition a computer containing irreplaceable data without a tested backup.

Beginner recommendation

Use a virtual machine, create a clean snapshot, and practice there before considering a direct installation.

3.11 Mac computers

There is no separate “Mac edition” of Kali. Intel Macs use AMD64 images, while Apple Silicon Macs require ARM64 images.

On Apple Silicon, VMware Fusion, Parallels, and UTM are common choices. Many tools work normally, but some x86-only packages, drivers, and hardware workflows may differ.

Direct installation on Mac hardware can be model-specific. A VM is the safer beginning for most learners.

3.12 Practical checklist

1. Verify whether the Mac is Intel or Apple Silicon before downloading.
2. Use an ARM64 Kali image on M-series Macs.
3. Expect external Wi-Fi adapters to require compatible hardware and VM USB access.

Beginner recommendation

Use a virtual machine, create a clean snapshot, and practice there before considering a direct installation.

3.13 First boot, updates, and safe defaults

1. Change any default or temporary password.
2. Confirm the date, time zone, keyboard layout, and network connection.
3. Update package information and apply normal upgrades.
4. Restart when the kernel or core system components are updated.
5. Create a clean snapshot after the system is stable.
6. Create a dedicated folder for each lab and keep notes separate from tool output.

```
sudo apt update
sudo apt full-upgrade -y
sudo reboot
```

Why full-upgrade?

Kali is a rolling distribution. The official documentation commonly recommends full-upgrade so package relationships can be handled correctly. Review proposed removals before accepting unexpected changes.

3.14 Essential Linux commands

Command	Purpose
pwd	Show the current directory.
ls -la	List files, including hidden files.
cd folder	Move into a folder.
mkdir lab-name	Create a directory.
cp / mv	Copy or move files.
cat / less	Read text output.
grep	Search text.
ip addr	View network interfaces and addresses.
ss -tulpn	View listening network sockets.
man tool	Open a manual page.
tool --help	Show command help.

3.15 Detailed Installation Walkthroughs

This section explains each installation choice slowly and in plain language. A virtual machine is the safest starting point for most new learners because it keeps Kali separate from the main operating system and makes it easy to undo mistakes with a snapshot.

3.16 Before you download anything

- ✓ Use only the official Kali Linux website and the official virtualization vendor website.
- ✓ Check whether your computer uses an Intel/AMD processor or an Apple Silicon processor. Apple Silicon Macs use ARM64 images.
- ✓ Make sure important files are backed up before changing partitions, firmware settings, or virtualization features.
- ✓ For a normal Kali security lab, plan for at least 8 GB of host memory, although 16 GB is much more comfortable.
- ✓ Keep at least 80 GB of free storage for a virtual machine. Local AI models may require much more space.

[Official Kali downloads](#)

[How to verify an official Kali image](#)

3.17 Choose the correct Kali image

Open the official Kali download page before choosing an image.

- ✓ **For VMware, VirtualBox, or Hyper-V on an Intel or AMD Windows computer, choose the 64-bit AMD64 image.**
- ✓ **For an Apple Silicon Mac, such as an M1, M2, M3, or newer model, choose the ARM64 installer image.**
- ✓ **For VMware and VirtualBox, the official prebuilt virtual-machine image is usually easiest because Kali has already been installed.**
- ✓ **For Hyper-V, a separate partition, or a dedicated computer, use the official Installer image unless Kali provides a current prebuilt image that matches your exact platform.**
- ✓ **Record where the downloaded file is saved. Most browsers place it in the Downloads folder.**

3.18 VMware Workstation on Windows - easiest choice for many beginners

Use this method when you want strong desktop integration, snapshots, and straightforward USB device support. The names of buttons can vary slightly by VMware version.

[Download VMware Workstation](#)

[Download the official Kali VMware image](#)

[Kali guide for importing the prebuilt VMware image](#)

1. **Check that hardware virtualization is enabled. In Windows, open Task Manager, choose Performance, and select CPU. Look for “Virtualization: Enabled.”**
2. **Install VMware Workstation from the official VMware website. Restart Windows if the installer asks you to do so.**
3. **Download the official Kali VMware AMD64 archive. Do not download a file from an unknown mirror or video description.**
4. **Use 7-Zip to extract the downloaded .7z archive. On Windows 11, right-click the file and choose Show more options if the 7-Zip menu is hidden.**
5. **Open VMware Workstation. Choose Open a Virtual Machine, then select the .vmx file inside the extracted Kali folder.**
6. **Before starting Kali, open the virtual-machine settings. A good beginner configuration is 4 processor cores, 8 GB of memory, and the disk size supplied by the image.**
7. **Keep the network adapter set to NAT for the first lessons. NAT allows Kali to reach the Internet through the host while reducing direct exposure to the local network.**
8. **Start the virtual machine. The official prebuilt image may initially use kali as both the username and password. Change the password immediately.**
9. **Run system updates, shut down Kali cleanly, and create a snapshot named Clean Install. This gives you a safe recovery point.**
10. **Do not enable shared folders or drag-and-drop until you understand the privacy risk. Shared features can expose host files to the guest system.**

3.19 Hyper-V on Windows 11 Pro, Enterprise, or Education

Use Hyper-V when it is already part of your Windows environment. Windows Home normally does not include the full Hyper-V feature. Hyper-V can also affect how some other virtualization products work, so use one main platform at a time when possible.

[Microsoft Hyper-V requirements and setup](#)

[Official Kali Hyper-V installation guide](#)

[Official Kali prebuilt Hyper-V import guide](#)

[Kali Enhanced Session Mode guide](#)

1. Open Windows Search and type Turn Windows features on or off.
2. Select Hyper-V, including Hyper-V Management Tools and Hyper-V Platform. Choose OK and restart the computer.
3. Open Hyper-V Manager from the Start menu.
4. Choose New, then Virtual Machine. Give the VM a clear name such as Kali-Lab.
5. Choose Generation 2 unless the current Kali documentation specifically directs you to another choice.
6. Assign startup memory. Eight GB is a comfortable beginner value when the host has at least 16 GB. Dynamic Memory can be enabled if the host needs flexibility.
7. Connect the VM to the Default Switch for a simple NAT-style Internet connection.
8. Create a virtual hard disk of at least 80 GB. Choose a larger disk if you plan to install local AI models.
9. Attach the official Kali Installer ISO, or follow Kali's current prebuilt Hyper-V import guide.
10. If the VM will not boot, review the Secure Boot setting. Kali documentation may instruct you to disable Secure Boot for that VM or select a compatible certificate template.
11. Complete the graphical Kali installer. Use the guided option that uses the entire virtual disk. This virtual disk is only a file; it is not the physical Windows drive.
12. After the first successful update, create a Hyper-V checkpoint named Clean Install.
13. For improved resizing and clipboard behavior, follow the official Enhanced Session Mode guide and use kali-tweaks inside Kali.

3.20 Oracle VirtualBox on Windows, Linux, or Intel Mac

VirtualBox is free and widely used. It is a good option when VMware or Hyper-V is unavailable, although USB and graphics behavior may require more setup.

[Download Oracle VirtualBox](#)

[Download the official Kali VirtualBox image](#)

[Kali guide for importing the prebuilt VirtualBox image](#)

[Kali VirtualBox guest installation guide](#)

1. Download and install VirtualBox from Oracle's official website.
2. Download the official Kali VirtualBox archive and extract it with 7-Zip or another trusted archive tool.
3. Open VirtualBox and choose Add. Browse to the extracted Kali folder and select the .vbox file.
4. Open Settings for the VM. Assign about 4 processor cores and 8 GB of memory when the host has enough resources.
5. Use NAT networking for the first lessons.
6. Start Kali and sign in. Change the default password if the image uses one.
7. Update Kali, shut it down, and create a snapshot named Clean Install.
8. If the screen does not resize correctly, confirm that the VirtualBox guest packages are installed. Kali normally installs them automatically in supported VM setups.
9. Install the Oracle Extension Pack only when you need its features and only when its version exactly matches the installed VirtualBox version.

3.21 Kali on Apple Silicon Mac - M1, M2, M3, and newer

Apple Silicon Macs use ARM64 processors. An AMD64 Kali image is not the correct choice for normal virtualization on these Macs.

[Kali ARM64 installer downloads](#)

[VMware Fusion for Mac](#)

[Kali VMware Fusion guide for Apple Silicon](#)

[Parallels Desktop](#)

[Kali in Parallels guide](#)

[UTM for Mac](#)

[Kali in UTM guide](#)

1. **Open the Apple menu, choose About This Mac, and confirm that the computer lists an Apple M-series chip.**
2. **Choose one virtualization product: VMware Fusion, Parallels Desktop, or UTM. Install it from the official vendor website.**
3. **Download the Kali ARM64 Installer ISO. Do not choose AMD64 for an Apple Silicon VM.**
4. **Create a new virtual machine and select Linux or Other Linux ARM64 when prompted for the operating system type.**
5. **Assign at least 4 processor cores, 8 GB of memory, and 80 GB of storage when the Mac has enough capacity.**
6. **Attach the ARM64 ISO and start the VM.**
7. **Use the graphical installer and install Kali onto the virtual disk created for the VM.**
8. **After the first update, install the guest integration tools recommended by the chosen virtualization product.**
9. **Create a snapshot before adding security tools or changing important settings.**
10. **Remember that a few security tools or drivers may behave differently on ARM64. Check the official tool documentation when a package is unavailable.**

3.22 Intel-based Mac

Intel Macs normally use the AMD64 Kali image. VMware Fusion, VirtualBox, or Parallels may be used depending on current vendor support for the macOS version.

[Kali virtualization documentation](#)

1. **Confirm that About This Mac identifies an Intel processor.**
2. **Install a supported virtualization program from its official website.**
3. **Download the official Kali AMD64 image or installer ISO.**
4. **Create or import the VM, then assign reasonable memory, processor, and disk resources.**
5. **Use NAT networking first, update Kali, and create a clean snapshot.**

3.23 Separate partition or dual boot with Windows

This method gives Kali direct hardware access, but it carries more risk than a VM. A partitioning mistake can make Windows or personal files unavailable. New learners should normally practice in a VM first.

[Official Kali dual-boot guide](#)

[Official Kali hard-disk installation guide](#)

1. **Back up all important files to a separate drive or trusted cloud service.**
2. **Save the Windows BitLocker recovery key. Do not continue until you know where that key is stored.**
3. **Create a Windows recovery drive and confirm that Windows starts normally.**
4. **Disable Windows Fast Startup. Fast Startup can leave Windows partitions in a state that Linux should not modify.**

5. **Open Windows Disk Management and shrink the Windows partition. Leave the new space unallocated; do not format it in Windows.**
6. **Download the official Kali Installer ISO and verify its checksum.**
7. **Create a bootable USB drive using a trusted imaging program. Be certain you select the USB drive, not the computer's main disk.**
8. **Restart the computer and open the UEFI boot menu. Choose the USB device in UEFI mode.**
9. **Start the graphical installer. When partitioning appears, choose the option that uses the largest continuous free space, or manually select only the unallocated space.**
10. **Never choose Use entire disk when Windows and personal files must remain on the computer.**
11. **Allow the installer to configure the GRUB boot menu. After installation, test both Kali and Windows.**
12. **If Windows requests the BitLocker recovery key after the boot configuration changes, enter the saved key.**
13. **Update Kali and keep the recovery USB available. Do not remove the Windows backup after only one successful boot.**

3.24 Dedicated computer installation

A dedicated computer is a strong long-term choice for wireless adapters, USB devices, GPU work, and full hardware access. The computer should contain no important data before installation.

1. **Back up anything that must be kept. The installation can erase the entire drive.**
2. **Download and verify the official Kali Installer ISO.**
3. **Create the bootable USB and start the computer from it.**
4. **Choose Graphical install.**
5. **Select the language, location, keyboard, user account, and time-zone information.**
6. **When partitioning appears, use Guided - use entire disk only when the computer is truly dedicated to Kali and contains no needed operating system or files.**
7. **Use encrypted LVM when the computer may store sensitive notes or evidence and you can safely manage the encryption passphrase.**
8. **Complete the installation, remove the USB when prompted, and restart.**

Update Kali before installing additional tools.

3.25 First boot checklist for every installation

1. Open a terminal.
2. Run `sudo apt update` to refresh the package lists.
3. Run `sudo apt full-upgrade -y` to install current updates. Read prompts before accepting unusual changes.
4. Restart Kali after a major kernel or system update.
5. Confirm the date, time, keyboard, network, and screen resolution.
6. Create a snapshot or checkpoint if Kali is running as a VM.
7. Create a folder for labs and notes. Keep client or personal data out of beginner exercises.
8. Use NAT networking until a lesson explains why another network mode is needed.
9. Never connect a security tool to a real target merely to see what happens.

3.26 Virtualization links at a glance

Platform or resource	Official link
----------------------	---------------

Platform or resource	Official link
Kali downloads	Official resource - kali.org
VMware Workstation/Fusion	Official resource - vmware.com
Oracle VirtualBox	Official resource - virtualbox.org
Microsoft Hyper-V	Official resource - learn.microsoft.com
Parallels Desktop	Official resource - parallels.com
UTM for Mac	Official resource - mac.getutm.app
Kali virtualization guides	Official resource - kali.org

4. Building a Safe Practice Lab

Building a Safe Practice Lab

A safe lab gives you permission to make mistakes. It separates practice targets from real systems and makes recovery possible. The simplest lab is one Kali VM plus an assigned Hack The Box target. A local lab may add intentionally vulnerable virtual machines or containers on an isolated host-only network.

Never use a public target as a substitute

A tutorial showing TARGET_IP does not authorize you to replace it with a school, employer, public website, neighbor, or random Internet address.

4.1 Hack The Box as the primary practice area

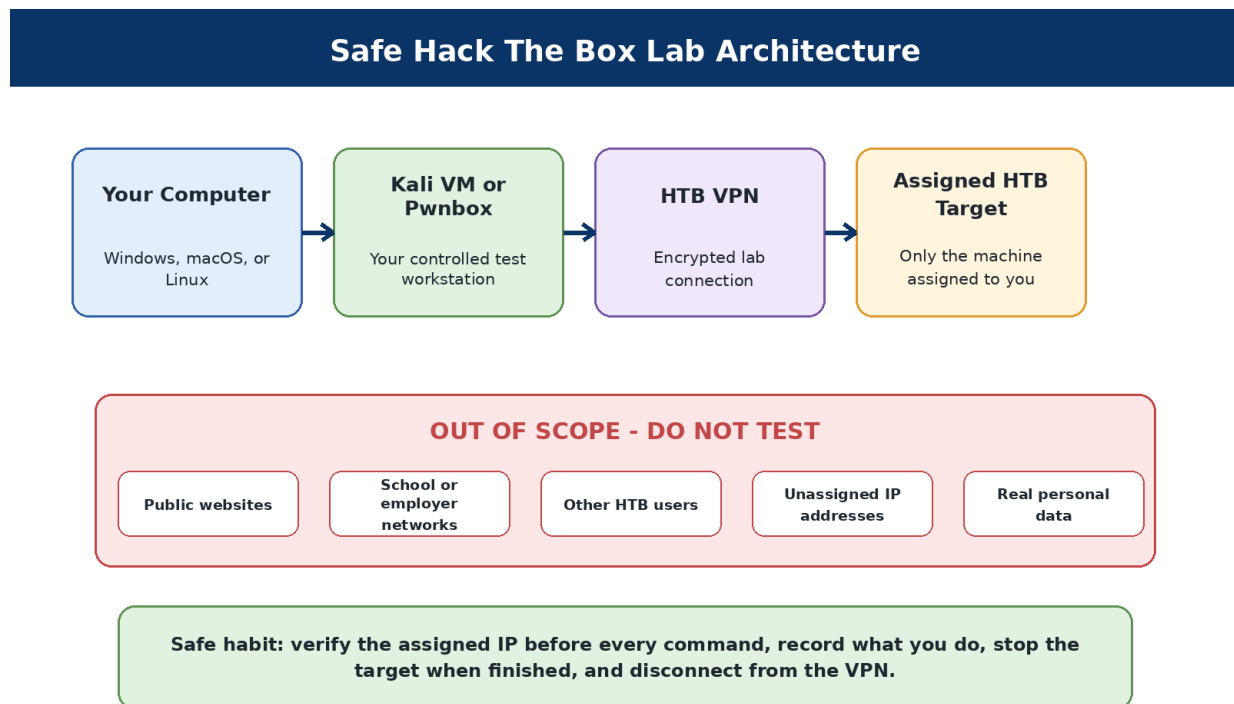


Figure 2. The safe path from the learner’s computer to an assigned Hack The Box target.

Hack The Box Starting Point is designed for absolute beginners and provides guided machines with explanations. Learners can connect through OpenVPN from Kali or use Pwnbox, a browser-based environment. Follow the current platform rules and never publish restricted active-machine solutions, flags, credentials, or spoilers.

[Hack The Box Starting Point](#)

[HTB Getting Started](#)

[HTB Academy](#)

[HTB Platform Rules](#)

[Introduction to Pwnbox](#)

4.2 Safe HTB workflow

Follow this sequence for each authorized Hack The Box lab session:

1. **Sign in and choose a Starting Point machine or another lab you are permitted to use.**
2. **Start or spawn the target and record the assigned IP address.**
3. **Download your VPN configuration or launch Pwnbox.**

4. **Create a local evidence folder named for the lab.**
5. **Connect to the VPN and confirm the connection.**
6. **Verify the target IP again before every command.**
7. **Begin with low-impact discovery.**
8. **Record findings and reasons for each next step.**
9. **Stop the target and disconnect when finished.**

```
mkdir -p ~/labs/starting-point/example/{notes,scans,evidence}  
cd ~/labs/starting-point/example  
sudo openvpn /path/to/your-lab.ovpn
```

Protect the VPN file

Your .ovpn file may contain account-specific access information. Do not upload it to GitHub, paste it into public AI tools, or share it with another person.

5. AI Tools for Cybersecurity Learning

AI Tools for Cybersecurity Learning

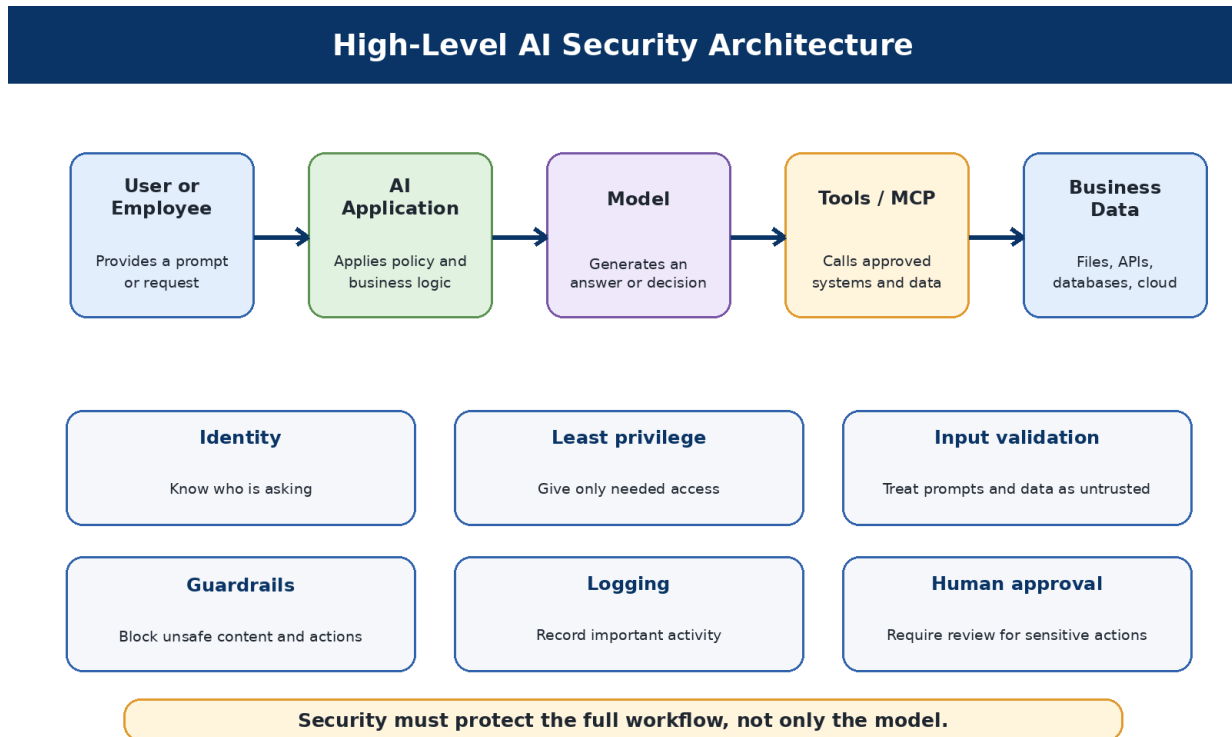


Figure 3. Security controls must protect the complete AI workflow.

AI can help a beginner interpret output, organize notes, generate study questions, and compare documentation. It can also be wrong, overconfident, unsafe, or unaware of your authorization. Treat it as a study assistant, not as an authority or permission system.

AI safety rule

Never paste real credentials, VPN files, tokens, client data, malware from an unknown source, private forensic evidence, or confidential scan results into a public AI service.

5.1 Ollama

LOCAL MODEL RUNNER

What it is and why it matters

Runs supported language models on the learner's own computer. Useful when privacy or offline access matters and the computer has enough memory.

When to use it

- Explaining sanitized command output locally.
- Creating study questions from your own notes.
- Drafting a remediation summary without uploading data.

When not to use it

Do not assume local means perfectly secure. Large models may overwhelm an older computer.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
ollama --version  
ollama list
```

First safe exercise

Install from the official Ollama source, start the service, download a small model, and ask it to explain a harmless command such as `ip addr`.

What to look for

Does the answer distinguish an IP address, interface, and loopback device? Can you confirm its explanation with `man ip` or official documentation?

Common beginner mistakes

Downloading a model that is too large. Treating a plausible answer as verified fact.

Risk level

Low operational risk when used with non-sensitive data. Resource use can be high.

Using AI responsibly with this tool

Ask AI to explain the result, then verify the explanation with the tool's help output, manual page, or official documentation. Remove IP addresses, usernames, secrets, and unique client details before sharing output externally.

Official resources

[Ollama](#)

5.2 Open WebUI

BROWSER INTERFACE FOR LOCAL OR CONNECTED AI MODELS

What it is and why it matters

Provides a familiar chat interface and can connect to Ollama and other supported back ends. Useful for learners who prefer a browser interface and want organized conversations.

When to use it

Keeping separate study chats for networking, web security, and forensics. Using a local model through a graphical interface.

When not to use it

Do not expose Open WebUI to the Internet without strong security. Do not upload secrets or evidence without understanding storage.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
docker --version  
docker ps
```

First safe exercise

Run Open WebUI in a local Docker container, connect it to Ollama, and create a study conversation that contains only fictional data.

What to look for

1. Can the interface reach the selected model?
2. Where are conversations stored?
3. Can another user on the host access them?

Common beginner mistakes

Publishing the service on all interfaces. Using an untrusted container command without review.

Risk level

Medium configuration risk. A poorly exposed service can create privacy and access-control problems.

Using AI responsibly with this tool

Ask AI to explain the result, then verify the explanation with the tool's help output, manual page, or official documentation. Remove IP addresses, usernames, secrets, and unique client details before sharing output externally.

Official resources

[Open WebUI documentation](#)

5.3 Promptfoo

LLM EVALUATION AND RED-TEAM FRAMEWORK

What it is and why it matters

Runs repeatable tests against prompts, models, and AI applications. Useful when testing whether an AI system handles unsafe or adversarial prompts consistently.

When to use it

- ✓ Comparing model responses to the same test set.
- ✓ Testing prompt-injection defenses in your own application.
- ✓ Documenting pass/fail criteria.

When not to use it

Do not target an AI service you are not authorized to test. Do not send confidential prompts to external providers.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
promptfoo --version
promptfoo init
```

First safe exercise

Create a small local evaluation with harmless prompts: one normal question, one instruction-conflict test, and one request for a secret that does not exist.

What to look for

- ✓ Did the model follow the intended system instruction?
- ✓ Are the test criteria measurable?
- ✓ Can another learner reproduce the result?

Common beginner mistakes

Confusing a demonstration with a complete security assessment. Using vague assertions that always pass.

Risk level

Medium risk. Tests can send large numbers of requests or sensitive text to providers.

Using AI responsibly with this tool

Ask AI to explain the result, then verify the explanation with the tool's help output, manual page, or official documentation. Remove IP addresses, usernames, secrets, and unique client details before sharing output externally.

Official resources

[Promptfoo documentation](#)

5.4 Giskard

AI TESTING AND EVALUATION TOOLKIT

What it is and why it matters

Helps evaluate machine-learning and generative-AI systems for quality and security issues. Useful when a project needs structured tests, reports, and repeatable checks.

When to use it

Testing a model or agent you own. Building quality and security checks into the development process.

When not to use it

Do not install packages globally when a virtual environment is more appropriate. Do not assume every scanner result is a confirmed vulnerability.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
python3 -m venv .venv
source .venv/bin/activate
python -m pip show giskard
```

First safe exercise

Create a virtual environment, install only the needed package set, and run a documented example against non-sensitive sample data.

What to look for

- Which test failed?
- What evidence supports the failure?
- Can it be reproduced manually?

Common beginner mistakes

Mixing incompatible Python environments. Publishing test data containing private information.

Risk level

Medium risk, mainly related to dependencies, data handling, and external model calls.

Using AI responsibly with this tool

Ask AI to explain the result, then verify the explanation with the tool's help output, manual page, or official documentation. Remove IP addresses, usernames, secrets, and unique client details before sharing output externally.

Official resources

[Giskard documentation](#)

5.5 LangChain

FRAMEWORK FOR MODEL-POWERED APPLICATIONS**What it is and why it matters**

Provides components for prompts, tools, retrieval, memory, and agents. Useful for building a controlled learning project that connects a model to documents or functions.

When to use it

Creating a small RAG demonstration from public notes. Learning how agents select tools.

When not to use it

Do not give an experimental agent unrestricted shell access. Do not use it as a security boundary.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
python -m pip show langchain
```

First safe exercise

Build a minimal application that answers questions from a short public text file. Keep tools disabled during the first exercise.

What to look for

- Does the answer cite the supplied text?
- What happens when the answer is absent?
- Can the model invent a source?

Common beginner mistakes

Starting with a complex autonomous agent. Ignoring dependency and version changes.

Risk level

Medium to high risk when agents can invoke tools or access sensitive data.

Using AI responsibly with this tool

Ask AI to explain the result, then verify the explanation with the tool's help output, manual page, or official documentation. Remove IP addresses, usernames, secrets, and unique client details before sharing output externally.

Official resources

[LangChain documentation](#)

5.6 LlamaIndex

DATA AND RETRIEVAL FRAMEWORK

What it is and why it matters

Helps connect language models to documents, indexes, and retrieval workflows. Useful for learning RAG and the security implications of untrusted knowledge sources.

When to use it

Indexing public course notes. Testing whether retrieved passages support an answer.

When not to use it

Do not ingest private evidence into an external model path. Do not trust retrieved text as instructions.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
python -m pip show llama-index
```

First safe exercise

Index a small set of public text files and ask questions with answers that quote or cite the retrieved passages.

What to look for

- ✓ Was the correct passage retrieved?
- ✓ Did an embedded instruction change model behavior?
- ✓ How is source access controlled?

Common beginner mistakes

Confusing retrieval relevance with truth. Failing to separate data from instructions.

Risk level

Medium risk. RAG can leak indexed data or carry prompt injection from documents.

Using AI responsibly with this tool

Ask AI to explain the result, then verify the explanation with the tool's help output, manual page, or official documentation. Remove IP addresses, usernames, secrets, and unique client details before sharing output externally.

Official resources

[LlamaIndex documentation](#)

5.7 Aider

TERMINAL-BASED AI PAIR PROGRAMMER

What it is and why it matters

Helps edit code in a Git repository using supported AI models. Useful for understanding code changes, creating tests, and learning secure review habits.

When to use it

- ✓ Improving a small lab script.
- ✓ Adding error handling and comments.
- ✓ Reviewing a proposed patch before accepting it.

When not to use it

Do not run it in a repository containing secrets. Do not accept changes without reading the diff.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
aider --version
git status
```

First safe exercise

Create a disposable Git repository containing a harmless Python script, ask Aider to add input validation, and review the diff.

What to look for

1. What files changed?
2. Did the change add dependencies?
3. Do tests still pass?

Common beginner mistakes

Letting the tool edit the wrong repository. Committing generated secrets or unsafe code.

Risk level

Medium risk. It can modify many files and may send code to a model provider.

Using AI responsibly with this tool

Ask AI to explain the result, then verify the explanation with the tool's help output, manual page, or official documentation. Remove IP addresses, usernames, secrets, and unique client details before sharing output externally.

Official resources

[Aider documentation](#)

5.8 Open Interpreter

NATURAL-LANGUAGE INTERFACE THAT CAN EXECUTE LOCAL CODE

What it is and why it matters

Allows a model-assisted session to run code and interact with the local computer. Useful only in a disposable, well-scoped environment when the learner understands that generated commands may execute.

When to use it

Performing harmless data transformation in a lab folder. Learning to review proposed commands before execution.

When not to use it

Do not use it on a primary computer with valuable files. Do not grant broad access to credentials, browser profiles, or private evidence.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
interpreter --version
```

First safe exercise

Use a disposable VM snapshot and a folder containing fictional CSV data. Ask for a summary and approve only commands you understand.

What to look for

- ✓ Which command will run?
- ✓ Which files can it access?
- ✓ Can the task be done without elevated privileges?

Common beginner mistakes

1. Approving commands automatically.
2. Running as root.
3. Assuming a natural-language request cannot delete files.

Risk level

High risk compared with a normal chatbot because it may execute code and change files.

Using AI responsibly with this tool

Ask AI to explain the result, then verify the explanation with the tool's help output, manual page, or official documentation. Remove IP addresses, usernames, secrets, and unique client details before sharing output externally.

Official resources

[Open Interpreter documentation](#)

6. MCP, RAG, and AI Agents

6.1 RAG in plain language

Retrieval-augmented generation, commonly called RAG, allows an application to search approved documents and include relevant passages in a model prompt. The model then uses those passages while creating an answer. RAG can improve accuracy, but it can also expose documents to the wrong user if permissions are poorly designed.

6.2 Vector databases in plain language

A vector database stores numerical representations of text so an application can find content with a similar meaning. Examples include Chroma, FAISS, and Qdrant. The security question is not only whether the database is encrypted. The application must also check whether the current user is allowed to retrieve each source document.

6.3 Agents and tool use

An AI agent can choose actions, call APIs, search files, or run tools. This makes the system useful, but it also increases risk. An agent should have the minimum necessary permissions, require approval for high-impact actions, and maintain reliable logs.

6.4 Model Context Protocol (MCP): a core AI security principle

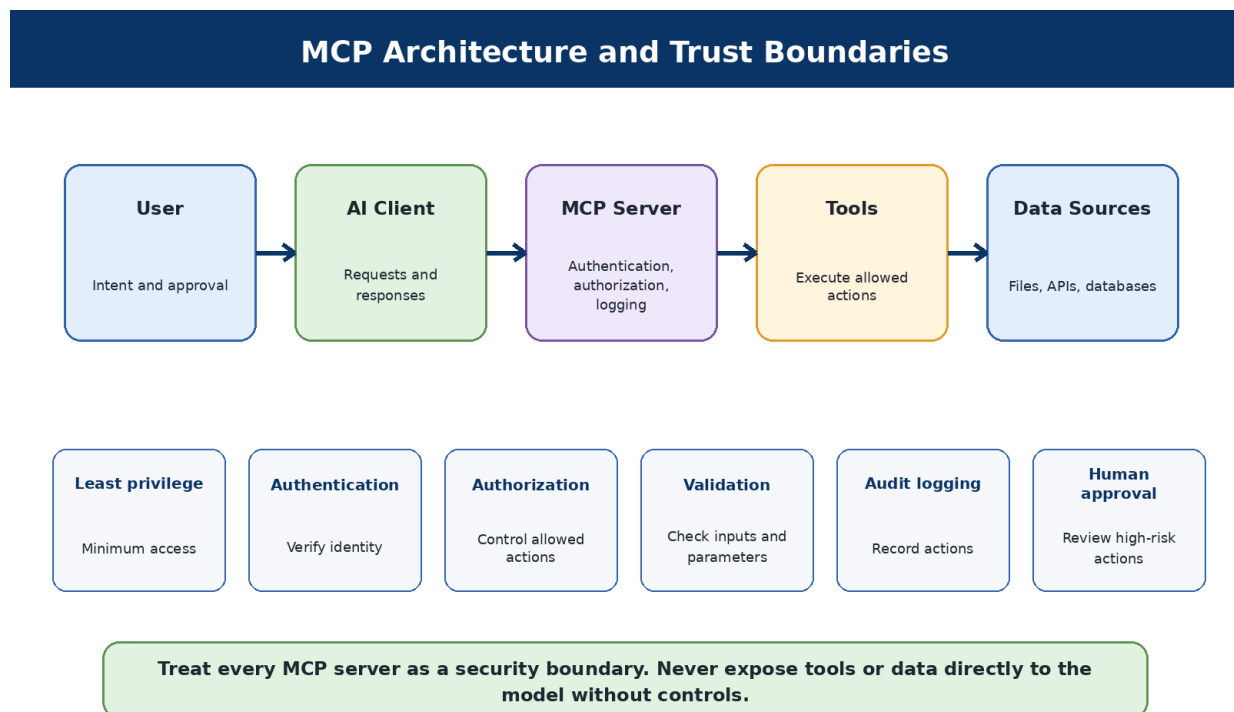


Figure 4. MCP components and the controls required at each trust boundary.

Model Context Protocol, or MCP, is a way for AI applications to connect to tools and data sources through a consistent interface. Treat every MCP server as a software integration requiring authentication, authorization, logging, input validation, and careful review of the data and actions it exposes.

6.5 Why MCP matters to employers

Modern AI systems increasingly need controlled access to tools, files, databases, cloud services, and business applications. MCP provides a common way for an AI application to discover and use those capabilities. Employers need people who understand not only how to connect an MCP server, but also how

to decide which tools the AI should be allowed to use, what data it may access, and how every action will be recorded and reviewed.

6.6 The security principles behind MCP

Treat every MCP server as a security boundary. Give it the smallest set of permissions needed for its purpose. Authenticate users and services, validate all inputs, protect secrets, restrict file and network access, keep audit logs, and require human approval for actions that could change data, send messages, run code, or affect production systems. A useful MCP connection is not automatically a safe MCP connection.

6.7 A beginner MCP review checklist

1. What business problem does this MCP server solve?
2. Which tools and data sources can it reach?
3. How are users, applications, and servers authenticated?
4. Are permissions limited to the minimum required?
5. Could untrusted prompts or documents trigger a dangerous tool call?
6. Which actions require a person to approve them?
7. Are tool calls, errors, and data access recorded in audit logs?
8. How can the connection be disabled quickly during an incident?

6.8 AI agents: the basic idea

An AI agent is software that uses an AI model to work toward a goal. A chatbot usually answers a question. An agent may go further by choosing a next step, reading information, calling a tool, creating a ticket, sending a message, or changing a cloud resource. The model provides reasoning and language; the tools provide the ability to act.

The most important security idea is simple: an agent can make mistakes, misunderstand instructions, or follow malicious instructions hidden in a document, webpage, email, or tool response. For that reason, an agent must never be trusted simply because it sounds confident.

6.9 The risks every employer should understand

- ✓ Prompt injection: malicious text may try to change the agent's instructions.
- ✓ Excessive permissions: an agent may be able to read, change, or delete more than its job requires.
- ✓ Data leakage: sensitive information may be placed in prompts, logs, memory, tool calls, or model responses.
- ✓ Unsafe tool use: the agent may send email, run code, approve a transaction, or change a system incorrectly.
- ✓ Untrusted knowledge: documents or websites used by the agent may contain false information or hidden instructions.
- ✓ Weak monitoring: an organization may not know what the agent accessed, decided, or changed.
- ✓ Cost and availability: loops, repeated tool calls, or very large requests can create unexpected cost or service disruption.

6.10 Microsoft Azure and Microsoft Foundry: security basics

In Azure, an employer may build agents with Microsoft Foundry Agent Service and connect them to Azure data, applications, and tools. The basic protections are the same ones used for other enterprise systems: give the agent its own managed identity, apply least privilege with Azure role-based access control, store secrets in a protected service such as Azure Key Vault, restrict network access, and log activity.

Use content-safety controls and Prompt Shields where appropriate to help detect harmful content, jailbreak attempts, and prompt-injection attacks. Require human approval before an agent changes production data,

sends external communications, runs code, or performs another high-impact action. Send relevant logs and alerts to the organization's monitoring and incident-response systems.

6.11 AWS and Amazon Bedrock: security basics

In AWS, agents may use Amazon Bedrock and connect to knowledge bases, Lambda functions, APIs, databases, and other services. Give each agent a narrowly scoped IAM role instead of broad administrator access. Use separate environments for development and production, protect data with encryption, and restrict network paths to the systems the agent actually needs.

Amazon Bedrock Guardrails can help filter unsafe content and detect prompt attacks, but guardrails are only one layer. Validate tool inputs and outputs, limit how many actions an agent can take, set time and spending limits, log prompts and tool calls according to privacy rules, and require approval for actions with financial, legal, security, or operational impact.

6.12 OpenAI API and ChatGPT-connected workflows: security basics

When an employer uses OpenAI models, the main risk is usually not the model alone. The greater risk appears when the model is connected to company files, email, browsers, databases, code, or external tools. Treat every connector and tool as a security boundary. Allow only the data and actions needed for the approved business purpose.

Keep system instructions and credentials out of user-visible content, validate tool arguments on the server, and do not let the model make final authorization decisions. Add confirmation before sensitive actions, protect against data exfiltration through links or tool calls, separate trusted instructions from untrusted content, and retain enough audit information to investigate what happened.

6.13 A minimum employer checklist for AI agents

- ✓ Maintain an inventory of every agent, owner, model, tool, data source, and business purpose.
- ✓ Assign a separate identity to the agent and use least privilege.
- ✓ Classify the data the agent may read, create, store, or transmit.
- ✓ Treat prompts, documents, webpages, emails, and tool responses as potentially untrusted input.
- ✓ Allow-list approved tools and validate every tool request outside the model.
- ✓ Require human approval for destructive, external, financial, legal, or production actions.
- ✓ Record prompts, tool calls, approvals, results, and errors while respecting privacy requirements.
- ✓ Test for prompt injection, data leakage, excessive agency, broken authorization, and unsafe output handling.
- ✓ Set rate limits, cost limits, timeouts, and emergency shutoff procedures.
- ✓ Review the agent after model, prompt, tool, permission, or data-source changes.

Beginner takeaway: secure the agent like a new employee who can work very quickly but still needs a clear job description, limited access, supervision, and a record of important actions.

6.14 Official starting references

[Microsoft Foundry Agent Service](#)

[Azure AI security best practices](#)

[AWS Security for agentic AI](#)

[AWS Generative AI security and least privilege](#)

[OpenAI agent link safety](#)

Career connection: MCP knowledge is becoming useful in AI security engineering, AI platform engineering, agent security, application security, cloud security, and AI governance roles. Beginners should learn the architecture and security questions first; production deployment comes later.

6.15 A simple AI security checklist

1. Know what data enters the model.
2. Know where prompts and outputs are stored.
3. Separate trusted instructions from untrusted user content.
4. Apply normal authentication and authorization outside the model.
5. Limit tools and agent permissions.
6. Test prompt injection and data-leakage scenarios.
7. Keep human approval for important or irreversible actions.
8. Monitor failures and create an incident-response process.

7. GRC and AI Governance

GRC means governance, risk, and compliance. It helps an organization decide who is responsible, what could go wrong, what controls are needed, and how the organization proves that it is meeting its obligations.

The diagram below shows GRC as a continuous cycle. Governance sets direction, risk management identifies and treats uncertainty, compliance and assurance confirm that controls work, and improvement feeds lessons back into the next cycle.

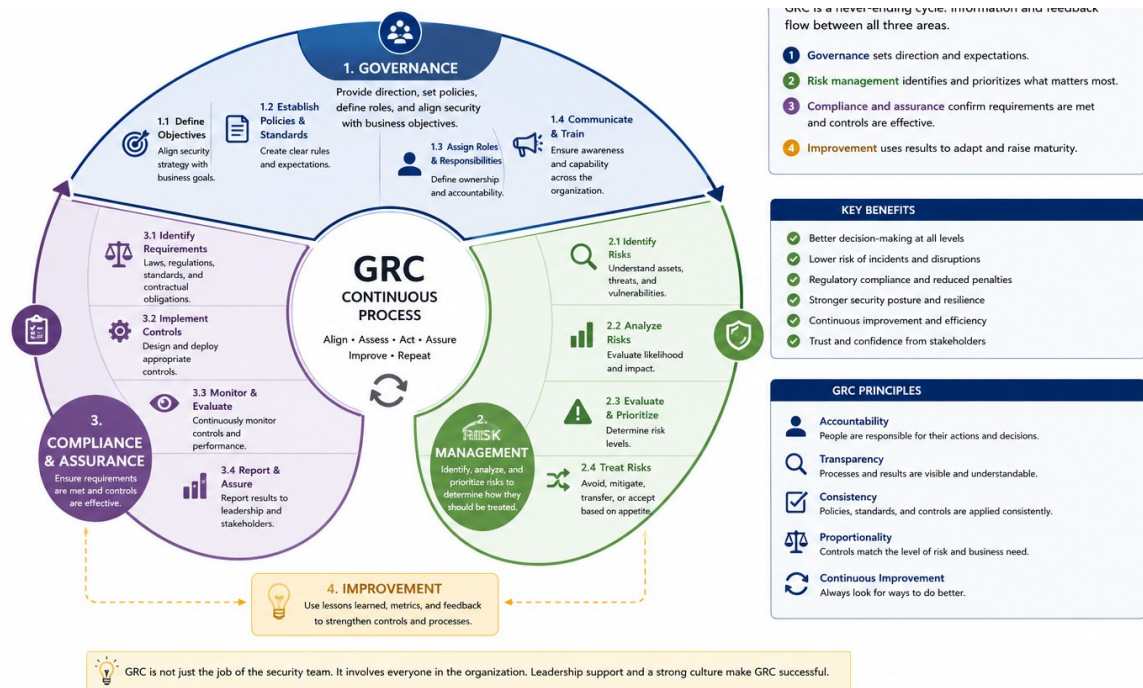


Figure 7.1 - GRC is a continuous process, not a one-time project.

7.1 Governance

Governance defines decision-making. It includes policies, roles, approvals, ownership, and oversight. In AI, governance may determine which tools are approved, what data may be used, and who can accept risk.

7.2 Risk

Risk considers what could happen, how likely it is, and how serious the result could be. A good risk statement connects a threat, a weakness, and a business impact.

7.3 Compliance

Compliance means meeting requirements from laws, regulations, contracts, standards, or internal policies. Passing an audit does not automatically mean a system is secure, but evidence and control testing can reveal whether expected safeguards are working.

7.4 Important beginner documents

1. Policy - states what the organization requires.
2. Standard - defines a mandatory technical or operational rule.
3. Procedure - gives the steps for completing a task.
4. Guideline - provides recommended practices.
5. Risk register - records risks, owners, decisions, and treatment plans.
6. Control evidence - shows that a control operated, such as a report, ticket, log, or approval.

7.5 AI governance questions

1. Do we have an inventory of AI systems and vendors?
2. What data is used for training, retrieval, prompts, and monitoring?
3. Who approves a new AI use case?
4. How is human oversight provided?
5. How are bias, privacy, security, and intellectual-property risks evaluated?
6. How are incidents reported and investigated?
7. What evidence shows that controls are working?

7.6 Frameworks to recognize

- ✓ NIST Cybersecurity Framework
- ✓ NIST AI Risk Management Framework
- ✓ ISO/IEC 27001 for information-security management
- ✓ ISO/IEC 42001 for AI management systems
- ✓ SOC 2 trust services criteria
- ✓ OWASP guidance for generative AI and LLM applications
- ✓ MITRE ATLAS for adversarial threats to AI systems

Do not try to memorize every framework. Learn the purpose of each framework and how controls, evidence, ownership, and risk decisions fit together.

8. Essential Kali Security Tools

8.1 Choosing the right Kali tool

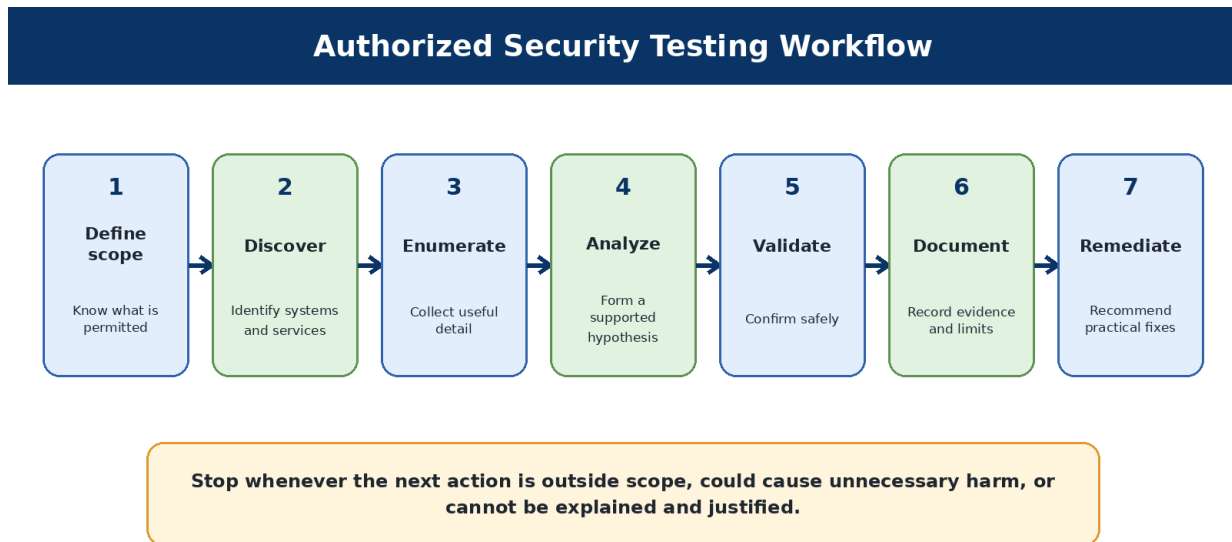


Figure 5. A safe and explainable security-testing workflow.

Kali includes many tools, but professionals do not run every tool against every target. They choose a tool because it answers a specific question. A simple workflow is: discover, enumerate, analyze, validate, document, and recommend remediation.

- ✓ Discover: What systems and services are present?
- ✓ Enumerate: What details can be learned from an authorized service?
- ✓ Analyze: What does the evidence suggest?
- ✓ Validate: Can the suspected weakness be confirmed safely?
- ✓ Document: What happened, what proves it, and what are the limitations?
- ✓ Remediate: What practical change would reduce the risk?
- ✓ Part V - Twenty Essential Kali Security Tools
- ✓ Part VI - Digital Forensics Fundamentals
- ✓ Part VII - Reporting What You Learn
- ✓ Your First 30 Days with Kali Linux

8.2 Twenty Essential Kali Security Tools

This list is a practical learning selection, not a claim that one ranking fits every professional. It covers discovery, traffic analysis, web testing, authentication, wireless work, Windows environments, exploit research, forensics, and open-source intelligence.

8.3 Nmap

NETWORK DISCOVERY AND SERVICE IDENTIFICATION

What it is and why it matters

Nmap discovers hosts, open ports, services, and selected system details. It gives a structured first view of an authorized target and helps you decide what to investigate next.

When to use it

Confirming which services an assigned lab machine exposes. Checking your own systems and lab network.

When not to use it

Do not scan networks you do not own or have permission to assess. Avoid aggressive options until you understand their traffic and impact.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
nmap --version
```

First safe exercise

Against an assigned HTB target, begin with a small TCP scan and save the output: `nmap -sV -oN scans/initial.txt TARGET\_IP`.

What to look for

- Open ports and service names.
- Service versions that may need manual confirmation.
- Filtered ports that may indicate a firewall.

Common beginner mistakes

- Scanning the wrong IP.
- Assuming a version string proves a vulnerability.
- Running every NSE script at once.

Risk level

Low to medium, depending on options. Scanning can trigger alerts and aggressive scripts may affect services.

Official resources

[Nmap on Kali](#)

[Nmap reference guide](#)

8.4 Wireshark

NETWORK TRAFFIC ANALYSIS**What it is and why it matters**

Wireshark captures and analyzes packets and protocols. It lets learners see what systems actually exchange on a network.

When to use it

Troubleshooting your lab connection. Learning DNS, TCP, TLS, and HTTP behavior.

When not to use it

Do not capture traffic where you lack authorization. Do not collect other people's credentials or private communications.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
wireshark --version
```

First safe exercise

Capture only your own lab interface while you run `ping` and a DNS lookup. Stop quickly and apply display filters such as `icmp` and `dns`.

What to look for

- Source and destination addresses.
- Protocol fields and request/response relationships.
- Encrypted versus unencrypted content.

Common beginner mistakes

- Capturing on the wrong interface.
- Leaving a capture running too long.
- Sharing packet files containing secrets.

Risk level

Medium privacy risk. Packet captures can contain credentials, tokens, and personal data.

Official resources

[Wireshark on Kali](#)

[Wireshark documentation](#)

8.5 Burp Suite Community Edition

WEB APPLICATION TESTING PROXY

What it is and why it matters

Burp intercepts and examines browser requests and application responses. It teaches how web applications communicate and supports careful manual testing.

When to use it

Testing an assigned web lab. Understanding cookies, headers, forms, and API requests.

When not to use it

Do not intercept another person's traffic. Do not use automated attacks against unapproved applications.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
burpsuite --help
```

First safe exercise

Configure a lab browser to use Burp, visit an assigned training application, and inspect one harmless GET request in HTTP history.

What to look for

- Method, path, parameters, headers, and cookies.
- Response status and content type.
- Which fields are controlled by the user.

Common beginner mistakes

- Installing Burp's CA certificate in a primary browser profile.
- Leaving the proxy enabled after the lab.
- Treating a scanner result as proven.

Risk level

Medium risk. Modified requests can change data or trigger application actions.

Official resources

[Burp Suite on Kali](#)

[PortSwigger Web Security Academy](#)

8.6 Metasploit Framework

VULNERABILITY RESEARCH AND VALIDATION FRAMEWORK

What it is and why it matters

Metasploit provides modules for research, validation, payloads, and controlled post-exploitation. It helps demonstrate the impact of known weaknesses in a lab.

When to use it

Validating a specific, confirmed lab vulnerability. Learning how exploit modules require options and target context.

When not to use it

Do not "try modules" on random services. Do not use persistence or destructive payloads outside an explicitly designed lab.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
msfconsole --version
```

First safe exercise

Open `msfconsole`, use `search` to research a module mentioned by a retired or Starting Point lab, and read `info` before setting a target. Do not launch it until the lab explicitly calls for that action.

What to look for

- ✓ Required options.
- ✓ Supported targets.
- ✓ Module references and side effects.

Common beginner mistakes

- ✓ Selecting a module based only on a product name.
- ✓ Ignoring target architecture.
- ✓ Running as root without need.

Risk level

High risk. Exploitation can crash services, create sessions, or alter a target.

Official resources

[Metasploit on Kali](#)

8.7 Gobuster

WEB CONTENT AND NAME DISCOVERY

What it is and why it matters

Gobuster uses wordlists to discover directories, files, DNS names, or virtual hosts. It finds content that may exist but is not linked from the visible website.

When to use it

Enumerating an assigned lab website. Comparing server responses to candidate paths.

When not to use it

Do not use large wordlists against unapproved or fragile systems. Do not interpret every response as sensitive content.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
gobuster version
```

First safe exercise

Run a small directory enumeration against an assigned lab URL using a modest wordlist and a conservative thread count.

What to look for

- ✓ Status codes.
- ✓ Response sizes.
- ✓ Redirects and false-positive patterns.

Common beginner mistakes

- ✓ Using the wrong mode.
- ✓ Ignoring extensions.
- ✓ Overloading the target with too many threads.

Risk level

Medium traffic risk. Wordlist enumeration can produce many requests.

Official resources

[Gobuster on Kali](#)

8.8 FFUF

FLEXIBLE WEB FUZZER

What it is and why it matters

FFUF places a FUZZ marker in a request and substitutes values from a wordlist. It supports directory, parameter, header, and virtual-host discovery with flexible filtering.

When to use it

Testing a specific input location on an assigned lab. Filtering responses by code, words, lines, or size.

When not to use it

Do not start with huge wordlists or high rates. Do not fuzz state-changing requests without understanding the consequences.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
ffuf -V
```

First safe exercise

Use a small wordlist against a lab directory path and first observe the baseline response for a nonexistent value.

What to look for

- ✓ **Consistent response-size patterns.**
- ✓ **Distinct status codes.**
- ✓ **Whether a finding is reproducible in the browser.**

Common beginner mistakes

- ✓ Failing to filter wildcard responses.
- ✓ Using too many threads.
- ✓ Fuzzing the wrong part of a URL.

Risk level

Medium traffic risk, potentially high with aggressive rates.

Official resources

[FFUF on Kali](#)

[FFUF project](#)

8.9 Nikto

WEB SERVER REVIEW SCANNER**What it is and why it matters**

Nikto checks web servers for known files, outdated signatures, and common configuration concerns. It provides a quick, explainable introduction to automated web server checks.

When to use it

Early review of an assigned training server. Generating items for manual verification.

When not to use it

Do not treat output as a final vulnerability report. Do not run against production without approved timing and rate considerations.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
nikto -Version
```

First safe exercise

Run Nikto only against a designated training web server and save the report. Manually confirm one low-risk informational item.

What to look for

- ✓ Server headers.
- ✓ Potential files or configuration issues.
- ✓ False positives and outdated signatures.

Common beginner mistakes

- ✓ Reporting every item as critical.
- ✓ Ignoring redirects or virtual hosts.
- ✓ Running without permission because it is “only a scan.”

Risk level

Medium. It generates recognizable scanning traffic and may trigger defenses.

Official resources

[Nikto on Kali](#)

8.10 sqlmap**SQL INJECTION TESTING AUTOMATION****What it is and why it matters**

sqlmap helps detect and validate SQL injection in web parameters. It demonstrates the serious impact of unsafe database queries when used in a purpose-built lab.

When to use it

A lab explicitly designed for SQL injection. Confirming a manually suspected injectable parameter.

When not to use it

Do not test arbitrary public forms. Do not dump data simply because the tool offers the option.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
sqlmap --version
```

First safe exercise

Use sqlmap only in a dedicated SQL-injection lesson and begin with detection-oriented settings. Stop before data extraction unless the lab specifically requires it.

What to look for

- ✓ Tested parameter and injection technique.
- ✓ Database fingerprint confidence.
- ✓ Requests that produced the result.

Common beginner mistakes

- ✓ Using maximum risk and level immediately.
- ✓ Sending state-changing requests.
- ✓ Collecting unnecessary data.

Risk level

High. It can generate many requests, modify data, or retrieve sensitive records.

Official resources

[sqlmap on Kali](#)

[sqlmap project](#)

8.11 OWASP ZAP

WEB PROXY AND SCANNER

What it is and why it matters

ZAP provides interception, crawling, passive analysis, and active scanning features. Its graphical workflow is approachable for learning web testing and distinguishing passive from active actions.

When to use it

Passive review of your own training application. Guided scanning in an isolated lab.

When not to use it

Do not active-scan systems without explicit approval. Do not assume all alerts are exploitable.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
zapproxy -version
```

First safe exercise

Proxy a local OWASP Juice Shop session through ZAP and review passive alerts before enabling any active scan.

What to look for

- ✓ Alert confidence and evidence.
- ✓ Difference between passive and active checks.
- ✓ Affected URL and parameter.

Common beginner mistakes

Starting an active scan accidentally. Reporting informational headers as severe findings.

Risk level

Medium to high depending on scanner use.

Official resources

[ZAP on Kali](#)

[ZAP documentation](#)

8.12 Hydra

ONLINE AUTHENTICATION TESTING

What it is and why it matters

Hydra tests username and password combinations against supported services. It can demonstrate weak credentials and missing account protections in a controlled lab.

When to use it

A lab that explicitly teaches credential auditing. Testing a small approved account list with known lockout rules.

When not to use it

Never test real accounts without authorization. Do not run when lockout, rate limits, or service stability are unknown.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
hydra -h
```

First safe exercise

Use only a purpose-built lab account and a tiny wordlist. Confirm the expected authentication protocol and stop after the lab objective.

What to look for

- ✓ Successful credential indication.
- ✓ Connection errors and false positives.
- ✓ Rate-limit or lockout behavior.

Common beginner mistakes

- ✓ Using the wrong service module.
- ✓ Testing a large list immediately.
- ✓ Causing account lockouts.

Risk level

High. It can lock accounts, overload authentication, and trigger incident response.

Official resources

[Hydra on Kali](#)

8.13 John the Ripper**OFFLINE PASSWORD-HASH AUDITING****What it is and why it matters**

John tests password hashes against candidate passwords and rules. Offline auditing helps demonstrate password strength without repeatedly contacting a login service.

When to use it

Hashes provided by a training lab. Auditing hashes obtained through an approved process.

When not to use it

Do not use stolen password databases. Do not upload hashes to public cracking services without permission.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
john --list=build-info
```

First safe exercise

Create hashes from fictional passwords in a lab and use a small wordlist to observe why predictable passwords fail.

What to look for

- ✓ Hash format.
- ✓ Recovered password and time required.
- ✓ Which password patterns were weak.

Common beginner mistakes

- ✓ Failing to identify the hash type.
- ✓ Exposing recovered passwords.
- ✓ Assuming unrecovered means strong.

Risk level

Medium confidentiality risk. Recovered credentials must be protected.

Official resources

[John on Kali](#)

8.14 Hashcat

HIGH-PERFORMANCE HASH AUDITING

What it is and why it matters

Hashcat uses CPUs or GPUs and supports many hash formats and attack modes. It teaches how password length, uniqueness, and predictability affect resistance to offline attacks.

When to use it

Controlled password-strength demonstrations. Authorized hash audits with suitable hardware.

When not to use it

Do not use hashes from breaches without lawful authority. Avoid overheating or destabilizing hardware.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
hashcat --version
```

First safe exercise

Use a small set of fictional hashes and a short wordlist. Monitor temperature and compare results with John.

What to look for

- ✓ Correct hash mode.
- ✓ Recovered candidates.
- ✓ Performance and hardware limits.

Common beginner mistakes

- ✓ Choosing the wrong mode.
- ✓ Running an unrealistic mask indefinitely.
- ✓ Ignoring thermal limits.

Risk level**Medium to high resource and confidentiality risk.****Official resources**[Hashcat on Kali](#)[Hashcat wiki](#)

8.15 Aircrack-ng

WIRELESS SECURITY TOOLKIT

What it is and why it matters

Aircrack-ng supports wireless capture, analysis, and approved security testing. It helps explain Wi-Fi channels, frames, authentication, and why wireless assessments need specialized hardware.

When to use it

Your own isolated access point and clients. A formal wireless assessment with explicit scope.

When not to use it

Do not test nearby networks. Do not disrupt other users or send deauthentication frames without explicit authorization.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
aircrack-ng --help
```

First safe exercise

Begin by identifying whether your external adapter supports monitor mode. Use only your own isolated test access point.

What to look for

Adapter mode, channel, BSSID, client, and capture quality.

Common beginner mistakes

- Assuming the built-in adapter supports monitor mode.
- Selecting the wrong network.
- Causing service disruption.

Risk level**High. Wireless actions can affect people beyond the intended target.****Official resources**[Aircrack-ng on Kali](#)

8.16 Bettercap

NETWORK RECONNAISSANCE AND TRAFFIC-MANIPULATION FRAMEWORK

What it is and why it matters

Bettercap supports discovery, inspection, and controlled network testing. It demonstrates how local-network trust can be abused and why encryption and segmentation matter.

When to use it

An isolated network built for the exercise. Observing hosts and protocols in your own lab.

When not to use it

Do not perform interception on shared, public, school, or workplace networks. Do not enable spoofing modules casually.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
bettercap -version
```

First safe exercise

Use a host-only lab network and begin with passive host discovery. Do not enable interception or spoofing in the first exercise.

What to look for

- ✓ Discovered hosts.
- ✓ Interfaces and network range.
- ✓ Which modules are active.

Common beginner mistakes

Starting on the wrong interface. Enabling active modules without reading their effect.

Risk level

High. Incorrect use can intercept traffic or disrupt connectivity.

Official resources

[Bettercap on Kali](#)

[Bettercap documentation](#)

8.17 Responder

WINDOWS NAME-RESOLUTION ASSESSMENT TOOL**What it is and why it matters**

Responder tests weaknesses in local Windows name-resolution and authentication behavior. It shows how insecure fallback protocols may expose authentication material.

When to use it

A dedicated Windows/Active Directory lab. An authorized internal assessment with strict handling requirements.

When not to use it

Never run on an ordinary corporate, school, public, or home network with uninvolved users. Do not collect or crack real user credentials outside explicit scope.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
responder -h
```

First safe exercise

In a purpose-built AD lab, first read the configuration and learn what listeners would start. Use analysis mode before any active poisoning where supported.

What to look for

- ✓ Protocols observed.
- ✓ Whether a response would be sent.
- ✓ What sensitive artifacts could be captured.

Common beginner mistakes

- ✓ Running on the primary network interface.
- ✓ Collecting unrelated user hashes.
- ✓ Leaving the tool running.

Risk level

Very high. It can capture authentication material and interfere with name resolution.

Official resources

[Responder on Kali](#)

8.18 NetExec**WINDOWS AND ACTIVE DIRECTORY ASSESSMENT FRAMEWORK****What it is and why it matters**

NetExec checks SMB, WinRM, LDAP, and other enterprise services using authorized credentials and enumeration. It provides a consistent way to assess large Windows environments and understand permissions.

When to use it

A controlled AD lab after learning SMB, LDAP, Kerberos, and credential handling. Authorized internal assessment.

When not to use it

Do not spray passwords or enumerate real domains without approval. Do not use privileged actions before confirming scope.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
nxc --version
```

First safe exercise

In an AD lab, query one assigned host with known lab credentials and use a read-only information option. Record exactly what permission was required.

What to look for

- ✓ Authentication result.
- ✓ Host and domain information.
- ✓ Read-only versus modifying modules.

Common beginner mistakes

- ✓ Using production credentials in a training command.

- ✓ Targeting an entire subnet accidentally.
- ✓ Confusing authentication with authorization.

Risk level
High. It can test credentials at scale and invoke remote actions.

Official resources

[NetExec documentation](#)

8.19 enum4linux-ng

SMB AND WINDOWS ENUMERATION

What it is and why it matters

enum4linux-ng gathers accessible information from SMB/Samba systems. It helps beginners organize users, groups, shares, policies, and domain information.

When to use it

After Nmap identifies SMB on an assigned target. A controlled Windows or Samba lab.

When not to use it

Do not enumerate systems outside scope. Do not assume anonymous access is harmless.

Authorization checkpoint
Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
enum4linux-ng -h
```

First safe exercise

Run against one assigned SMB lab target and export results to a file. Compare the output with manual `smbclient` observations.

What to look for

Shares, users, groups, policies, and domain names. Access-denied versus anonymous results.

Common beginner mistakes

Ignoring false or duplicate entries. Copying sensitive user lists into public notes.

Risk level
Medium. Enumeration can expose sensitive organizational details.

Official resources

[enum4linux-ng on Kali](#)

8.20 Searchsploit

LOCAL EXPLOIT DATABASE SEARCH

What it is and why it matters

Searchsploit searches a local catalog of public exploit and proof-of-concept references. It connects exact product versions to security research while keeping the search local.

When to use it

Research after identifying a precise product and version. Reading exploit code to understand prerequisites.

When not to use it

Do not run proof-of-concept code without review. Do not assume a search match proves vulnerability.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
searchsploit -h
```

First safe exercise

Search for a product used in a retired lab. Open the reference and identify affected versions, prerequisites, and whether the code modifies the target.

What to look for

- ✓ Version range.
- ✓ Exploit type and reliability.
- ✓ Required privileges and target platform.

Common beginner mistakes

- ✓ Matching only on a broad product name.
- ✓ Compiling unknown code as root.
- ✓ Skipping manual review.

Risk level

Research is low risk; executing unreviewed exploit code is high risk.

Official resources

[Searchsploit on Kali](#)

[Exploit Database](#)

8.21 Autopsy

GRAPHICAL DIGITAL FORENSICS PLATFORM**What it is and why it matters**

Autopsy helps examine disk images, files, metadata, browser artifacts, and timelines. It gives beginners a structured interface for forensic analysis.

When to use it

Sample forensic images. Authorized incident investigations using forensic copies.

When not to use it

Do not open original read-write evidence. Do not expose case data or recovered personal files.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
autopsy --help
```

First safe exercise

Create a case using a publicly available training image, calculate or verify its hash, and locate basic file system metadata.

What to look for

- ✓ Evidence source and hash.
- ✓ Time-zone settings.
- ✓ Recovered files and timeline context.

Common beginner mistakes

- ✓ Using the original device as working evidence.
- ✓ Misinterpreting timestamps.
- ✓ Exporting private artifacts carelessly.

Risk level

Medium privacy and evidence-integrity risk.

Official resources

[Autopsy on Kali](#)

[Autopsy documentation](#)

8.22 Maltego

RELATIONSHIP VISUALIZATION AND OSINT PLATFORM**What it is and why it matters**

Maltego maps relationships among public entities, infrastructure, and information sources. It helps learners see how small public clues can combine into a larger picture.

When to use it

Researching fictional or authorized organizations. Mapping your own public exposure.

When not to use it

Do not stalk, harass, or build invasive profiles of private individuals. Do not treat a visual connection as proof.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
maltego --help
```

First safe exercise

Use a fictional company or your own domain and a limited set of public transforms. Record source quality for every relationship.

What to look for

- ✓ Source of each entity.
- ✓ Confidence and possible alternative explanations.
- ✓ Data that should not be published.

Common beginner mistakes

Collecting more personal information than needed. Treating correlation as identity confirmation.

Risk level

Medium privacy and ethical risk.

Official resources

[Maltego on Kali](#)

[Maltego documentation](#)

9. Digital Forensics Fundamentals and Tools

9.1 Digital Forensics Fundamentals

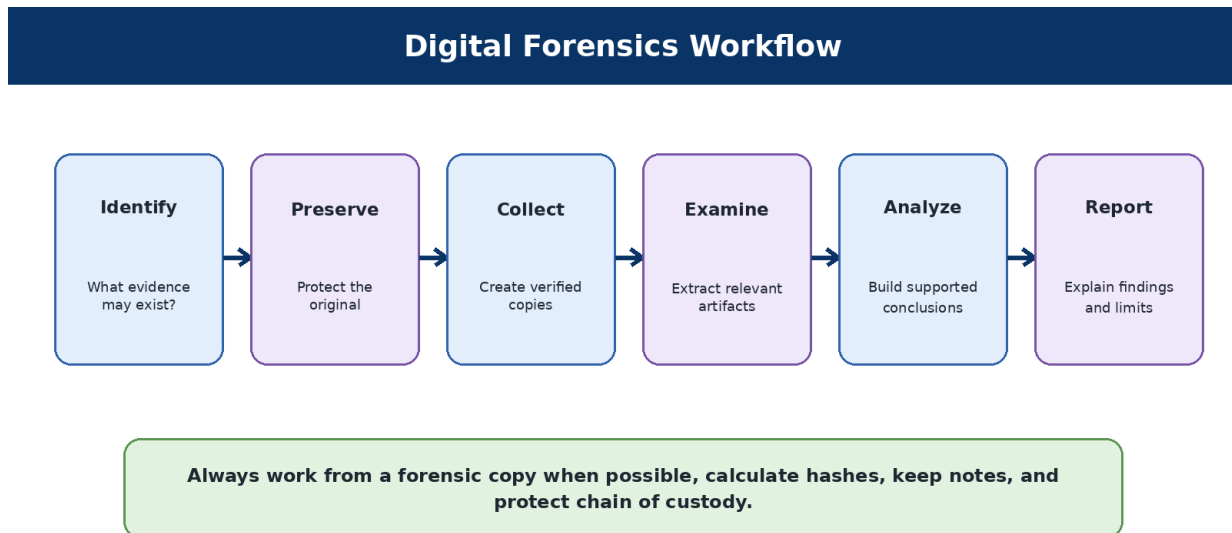


Figure 6. A basic digital-forensics workflow that protects original evidence.

Digital forensics is the disciplined identification, preservation, examination, analysis, and reporting of digital evidence. The goal is not simply to find interesting files. The goal is to produce accurate, repeatable conclusions while preserving integrity and respecting privacy.

Work from copies

When evidence matters, preserve the original, create a verified forensic image, record hashes, and conduct analysis on a working copy. A learner should use public training images rather than real personal devices.

Core concepts

- ❖ Chain of custody: a record of who handled evidence, when, why, and how.
- ❖ Hash: a reproducible digital fingerprint used to verify that evidence has not changed.
- ❖ Write blocker: hardware or software controls intended to prevent modification of source media.
- ❖ Timeline: an ordered view of events derived from file systems, logs, applications, and other artifacts.
- ❖ Artifact: a piece of data that may support an investigation, such as browser history, registry information, logs, or metadata.
- ❖ Finding versus conclusion: an observed artifact is not automatically proof of intent or identity.

9.2 Sleuth Kit

COMMAND-LINE FILE-SYSTEM FORENSICS

What it is and why it matters

Provides tools for examining disk images and file-system structures. Useful for learning repeatable, scriptable analysis beneath graphical interfaces.

When to use it

- ✓ Authorized incident response.
- ✓ Public training evidence.
- ✓ Your own deliberately prepared sample data.

When not to use it

Do not analyze someone else's device or account without lawful authority. Do not work from original evidence when preservation matters.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
fls -V
```

First safe exercise

List files from a public training image and compare allocated and deleted entries.

What to look for

- ✓ Record the source and hash.
- ✓ Separate observation from interpretation.
- ✓ Document time zone, tool version, and export location.

Common beginner mistakes

- ✓ Selecting the wrong device or image.
- ✓ Changing evidence.
- ✓ Overstating what an artifact proves.

Risk level

Medium evidence-integrity risk if the wrong device is selected.

Using AI responsibly with this tool

AI can help summarize sanitized timelines or explain file formats, but do not upload real evidence to a public model. Confirm every conclusion from the underlying artifact and tool output.

Official resources

[Sleuth Kit](#)

9.3 Guymager**FORENSIC IMAGING****What it is and why it matters**

Creates forensic images and calculates hashes. Useful when learning acquisition, evidence copies, and verification.

When to use it

- ✓ Authorized incident response.
- ✓ Public training evidence.
- ✓ Your own deliberately prepared sample data.

When not to use it

Do not analyze someone else's device or account without lawful authority. Do not work from original evidence when preservation matters.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
guymager
```

First safe exercise

Image a disposable USB device containing fictional files, never a device with real personal data.

What to look for

- ✓ Record the source and hash.
- ✓ Separate observation from interpretation.
- ✓ Document time zone, tool version, and export location.

Common beginner mistakes

- ✓ Selecting the wrong device or image.
- ✓ Changing evidence.
- ✓ Overstating what an artifact proves.

Risk level

High risk if source and destination are confused.

Using AI responsibly with this tool

AI can help summarize sanitized timelines or explain file formats, but do not upload real evidence to a public model. Confirm every conclusion from the underlying artifact and tool output.

Official resources

[Guymager on Kali](#)

9.4 ExifTool

METADATA EXAMINATION**What it is and why it matters**

Reads and writes metadata from many file formats. Useful for understanding timestamps, camera information, document properties, and hidden metadata.

When to use it

- ✓ Authorized incident response.
- ✓ Public training evidence.
- ✓ Your own deliberately prepared sample data.

When not to use it

Do not analyze someone else's device or account without lawful authority. Do not work from original evidence when preservation matters.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
exiftool -ver
```

First safe exercise

Run ExifTool on your own sample images and documents. Compare file-system times with embedded metadata.

What to look for

- ✓ Record the source and hash.
- ✓ Separate observation from interpretation.
- ✓ Document time zone, tool version, and export location.

Common beginner mistakes

- ✓ Selecting the wrong device or image.
- ✓ Changing evidence.
- ✓ Overstating what an artifact proves.

Risk level

Low when reading copies; writing metadata can alter evidence.

Using AI responsibly with this tool

AI can help summarize sanitized timelines or explain file formats, but do not upload real evidence to a public model. Confirm every conclusion from the underlying artifact and tool output.

Official resources

[ExifTool on Kali](#)

[ExifTool](#)

9.5 Binwalk**EMBEDDED DATA AND FIRMWARE ANALYSIS****What it is and why it matters**

Identifies signatures and embedded objects inside binary files. Useful for introductory concepts in firmware and file carving.

When to use it

- Authorized incident response.
- Public training evidence.
- Your own deliberately prepared sample data.

When not to use it

Do not analyze someone else's device or account without lawful authority. Do not work from original evidence when preservation matters.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
binwalk --help
```

First safe exercise

Analyze a publicly available sample firmware image and identify signatures without automatically executing the extracted content.

What to look for

- ✓ Record the source and hash.
- ✓ Separate observation from interpretation.
- ✓ Document time zone, tool version, and export location.

Common beginner mistakes

- ✓ Selecting the wrong device or image.
- ✓ Changing evidence.
- ✓ Overstating what an artifact proves.

Risk level

Medium. Extracted files may be untrusted.

Using AI responsibly with this tool

AI can help summarize sanitized timelines or explain file formats, but do not upload real evidence to a public model. Confirm every conclusion from the underlying artifact and tool output.

Official resources

[Binwalk on Kali](#)

9.6 Volatility 3

MEMORY FORENSICS

What it is and why it matters

Analyzes supported memory images to recover process, network, and operating-system artifacts. Useful for incident response and understanding what existed in memory at capture time.

When to use it

- ✓ Authorized incident response.
- ✓ Public training evidence.
- ✓ Your own deliberately prepared sample data.

When not to use it

Do not analyze someone else's device or account without lawful authority. Do not work from original evidence when preservation matters.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
vol -h
```

First safe exercise

Use a public Windows memory image and list basic process information. Verify plugin requirements and image compatibility.

What to look for

- ✓ Record the source and hash.
- ✓ Separate observation from interpretation.
- ✓ Document time zone, tool version, and export location.

Common beginner mistakes

- ✓ Selecting the wrong device or image.
- ✓ Changing evidence.
- ✓ Overstating what an artifact proves.

Risk level**High privacy risk; memory can contain credentials and private data.****Using AI responsibly with this tool**

AI can help summarize sanitized timelines or explain file formats, but do not upload real evidence to a public model. Confirm every conclusion from the underlying artifact and tool output.

Official resources

[Volatility 3 documentation](#)

9.7 Foremost**FILE CARVING****What it is and why it matters**

Recovers file-like content from raw data based on headers and signatures. Useful for understanding recovery when directory information is missing.

When to use it

- ✓ Authorized incident response.
- ✓ Public training evidence.
- ✓ Your own deliberately prepared sample data.

When not to use it

Do not analyze someone else's device or account without lawful authority. Do not work from original evidence when preservation matters.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
foremost -V
```

First safe exercise

Carve a small public practice image into a dedicated output directory and review false positives.

What to look for

- ✓ Record the source and hash.
- ✓ Separate observation from interpretation.
- ✓ Document time zone, tool version, and export location.

Common beginner mistakes

- ✓ Selecting the wrong device or image.
- ✓ Changing evidence.
- ✓ Overstating what an artifact proves.

Risk level**Medium storage and privacy risk.**

Using AI responsibly with this tool

AI can help summarize sanitized timelines or explain file formats, but do not upload real evidence to a public model. Confirm every conclusion from the underlying artifact and tool output.

Official resources

[Foremost on Kali](#)

9.8 bulk_extractor

FEATURE EXTRACTION

What it is and why it matters

Scans images for features such as email addresses, URLs, and other patterns without parsing every file system. Useful for triage and understanding why extracted indicators require context.

When to use it

- ✓ Authorized incident response.
- ✓ Public training evidence.
- ✓ Your own deliberately prepared sample data.

When not to use it

Do not analyze someone else's device or account without lawful authority. Do not work from original evidence when preservation matters.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
bulk_extractor -V
```

First safe exercise

Run against a public practice image and examine reports without assuming every string belongs to a user.

What to look for

- ✓ Record the source and hash.
- ✓ Separate observation from interpretation.
- ✓ Document time zone, tool version, and export location.

Common beginner mistakes

- ✓ Selecting the wrong device or image.
- ✓ Changing evidence.
- ✓ Overstating what an artifact proves.

Risk level

High privacy risk on real evidence.

Using AI responsibly with this tool

AI can help summarize sanitized timelines or explain file formats, but do not upload real evidence to a public model. Confirm every conclusion from the underlying artifact and tool output.

Official resources

[bulk_extractor project](#)

9.9 Plaso/log2timeline

TIMELINE GENERATION

What it is and why it matters

Collects timestamps and artifacts from many sources to create forensic timelines. Useful for reconstructing sequences of activity.

When to use it

- ✓ Authorized incident response.
- ✓ Public training evidence.
- ✓ Your own deliberately prepared sample data.

When not to use it

Do not analyze someone else's device or account without lawful authority. Do not work from original evidence when preservation matters.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
log2timeline.py --help
```

First safe exercise

Build a timeline from a small training image and filter it to a narrow time range.

What to look for

- ✓ Record the source and hash.
- ✓ Separate observation from interpretation.
- ✓ Document time zone, tool version, and export location.

Common beginner mistakes

- ✓ Selecting the wrong device or image.
- ✓ Changing evidence.
- ✓ Overstating what an artifact proves.

Risk level

Medium; wrong time-zone assumptions can mislead analysis.

Using AI responsibly with this tool

AI can help summarize sanitized timelines or explain file formats, but do not upload real evidence to a public model. Confirm every conclusion from the underlying artifact and tool output.

Official resources

[Plaso documentation](#)

9.10 YARA

PATTERN-BASED CLASSIFICATION

What it is and why it matters

Uses rules to identify files or memory matching defined byte and text patterns. Useful for malware triage and repeatable classification when rules are carefully written.

When to use it

- ✓ Authorized incident response.
- ✓ Public training evidence.
- ✓ Your own deliberately prepared sample data.

When not to use it

Do not analyze someone else's device or account without lawful authority. Do not work from original evidence when preservation matters.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
yara --version
```

First safe exercise

Write a harmless rule that identifies a fictional text marker in a sample directory.

What to look for

- ✓ Record the source and hash.
- ✓ Separate observation from interpretation.
- ✓ Document time zone, tool version, and export location.

Common beginner mistakes

- ✓ Selecting the wrong device or image.
- ✓ Changing evidence.
- ✓ Overstating what an artifact proves.

Risk level

Medium. Poor rules create false positives; untrusted samples remain dangerous.

Using AI responsibly with this tool

AI can help summarize sanitized timelines or explain file formats, but do not upload real evidence to a public model. Confirm every conclusion from the underlying artifact and tool output.

Official resources

[YARA documentation](#)

9.11 Ghidra

REVERSE ENGINEERING SUITE

What it is and why it matters

Disassembles and decompiles executable code for analysis. Useful for advanced learning about programs, malware, and vulnerabilities.

When to use it

- ✓ Authorized incident response.

- ✓ Public training evidence.
- ✓ Your own deliberately prepared sample data.

When not to use it

Do not analyze someone else's device or account without lawful authority. Do not work from original evidence when preservation matters.

Authorization checkpoint

Use this tool only on a system you own, a lab specifically assigned to you, or a system covered by clear written authorization. Publicly reachable does not mean publicly testable.

Check that it is available

```
ghidraRun
```

First safe exercise

Open a harmless compiled "hello world" program and identify strings and functions. Do not begin with live malware.

What to look for

- ✓ Record the source and hash.
- ✓ Separate observation from interpretation.
- ✓ Document time zone, tool version, and export location.

Common beginner mistakes

- ✓ Selecting the wrong device or image.
- ✓ Changing evidence.
- ✓ Overstating what an artifact proves.

Risk level

High when analyzing malicious samples; isolation is essential.

Using AI responsibly with this tool

AI can help summarize sanitized timelines or explain file formats, but do not upload real evidence to a public model. Confirm every conclusion from the underlying artifact and tool output.

Official resources

[Ghidra](#)

10. Reporting What You Learn

Reporting What You Learn

A security professional is judged not only by what they can discover, but by how clearly, accurately, and responsibly they communicate it. Begin reporting in your first lab.

10.1 Simple finding template

Field	What to write
Title	A clear description of the issue.
Scope	The exact authorized target.
Observation	What you directly saw.
Evidence	Relevant command, timestamp, and sanitized output.
Risk	What could happen and under what conditions.
Recommendation	A practical corrective action.

Field	What to write
Limitations	What you did not test or could not confirm.

10.2 Avoid these reporting mistakes

1. Calling a version number a confirmed vulnerability without validation.
2. Copying raw scanner output without explaining significance.
3. Using dramatic words such as “catastrophic” without evidence.
4. Including passwords, tokens, flags, or personal data in a public report.
5. Hiding uncertainty. A professional report clearly distinguishes confirmed facts, reasonable inferences, and open questions.

11. Your First 30 Days with Kali Linux

Your First 30 Days with Kali Linux

11.1 Week 1 - Build safe foundations

1. Read the ethics section.
2. Install Kali in a VM.
3. Update it and create a snapshot.
4. Learn files, directories, permissions, processes, and basic networking.
5. Create a lab notebook.

11.2 Week 2 - Learn to observe

1. Use Nmap on one assigned lab target.
2. Capture your own traffic with Wireshark.
3. Learn DNS, TCP, HTTP, and TLS at an introductory level.
4. Write one short finding.

11.3 Week 3 - Begin web and HTB practice

1. Complete beginner Starting Point machines.
2. Learn Burp HTTP history and basic Gobuster or FFUF use.
3. Use AI only to explain sanitized output, then verify it.
4. Review the HTB rules.

11.4 Week 4 - Connect the skills

1. Complete a small lab from discovery to reporting.
2. Use one forensic training image to learn hashing and metadata.
3. Review what actions were low impact, intrusive, or prohibited.
4. Choose the next learning path: penetration testing, SOC/incident response, forensics, cloud, GRC, or AI security.

What success looks like after 30 days

You can safely operate a Kali VM, identify an authorized target, run basic discovery, explain the difference between observation and exploitation, protect lab data, and write a simple evidence-based report. You are not expected to know every tool.

12. English for Technology Careers

A person does not need perfect English to begin a technology career. Many excellent professionals use English as a second or third language. However, practical English opens access to more documentation, training, communities, and international jobs.

12.1 Where English appears

1. Programming keywords and command-line options
2. Error messages and troubleshooting results
3. Official documentation and release notes
4. GitHub issues, pull requests, and security advisories
5. Team meetings, tickets, reports, and interviews
6. Research papers and early reports about new threats

12.2 A realistic goal

The goal is not to sound like a native speaker. The goal is to read instructions, understand an error, search for a solution, explain a problem, write a clear update, and describe your work during an interview. Technical English improves through daily use.

Beginners should start in the language they understand best and use English as an additional professional tool. Do not wait for perfect English before beginning cybersecurity or software development.

12.3 Free English Learning Resources Available Worldwide

Most of these resources provide free self-paced lessons. Some organizations also sell optional tutoring or live classes, so read the pricing page before enrolling in anything paid.

Resource	Best use	Official link
British Council LearnEnglish	Free videos, reading, listening, grammar, vocabulary, and level-based activities.	Official resource - learnenglish.britishcouncil.org
British Council free level test	An approximate starting-level check.	Official resource - learnenglish.britishcouncil.org
USA Learns	Structured adult English courses with free registration and progress tracking.	Official resource - usalearns.org
VOA Learning English	American English lessons, slower news, audio, vocabulary, and beginner courses.	Official resource - learningenglish.voanews.com
Cisco Skills for All	Free technology and cybersecurity learning that also builds technical English. Search the catalog for English for IT and Ethical Hacker.	Official resource - skillsforall.com
OpenLearn	Free courses from The Open University, including everyday and study English.	Official resource - open.edu
BBC Learning English	Free videos, pronunciation, grammar, vocabulary, and live lessons.	Official resource - bbc.co.uk
Duolingo	Free daily practice for vocabulary and basic grammar; best used with other speaking and listening resources.	Official resource - duolingo.com
EF SET	Free English-level tests and a shareable result; an assessment rather than a full course.	Official resource - efset.org

12.4 A simple weekly English plan

1. Study one structured lesson three times a week.

2. Listen to ten minutes of English every day.
3. Write down five technical words and use each in a sentence.
4. Keep error messages in their original English when searching for solutions.
5. Explain one Kali or AI concept aloud in simple English.
6. Measure progress every three to six months rather than every day.

13. Career Paths and Continued Learning

Path	Focus
SOC and incident response	Monitoring, triage, investigation, containment, and communication.
Penetration testing	Authorized assessment, validation, reporting, and remediation guidance.
Digital forensics	Evidence preservation, artifact analysis, timelines, and defensible conclusions.
Security engineering	Designing, configuring, and operating security controls.
Cloud security	Identity, data protection, configuration, logging, and workload security.
GRC	Governance, risk, compliance, policy, control design, and business communication.
AI security	Model evaluation, prompt injection, RAG security, data protection, and AI governance.

Kali is a useful laboratory, not a complete career. Employers value networking, operating systems, scripting, cloud, identity, communication, documentation, and ethical judgment. Build depth gradually and create a portfolio that contains sanitized lab reports rather than copied flags or unexplained screenshots.

1. I own the target or have explicit authorization.
2. The IP address, hostname, account, and time window are inside scope.
3. I understand whether the action is passive, active, intrusive, or modifying.
4. I know the expected output and stop condition.
5. I am saving output in the correct lab folder.
6. I am not exposing credentials, VPN files, client data, or flags.
7. I can explain why this command is necessary.

Lab folder pattern

```
~/labs/<platform>/<lab-name>/
├── notes/
├── scans/
├── evidence/
└── report/
```

Term	Entry-level meaning
Active Directory (AD)	Microsoft directory services used to manage users, computers, permissions, and policies in many organizations.
AI model	A computer system trained to recognize patterns or generate outputs such as text, images, or predictions.
Attack surface	The systems, services, applications, identities, devices, and paths that could be targeted.
Authentication	The process of proving who or what you are, commonly with a password, token, or biometric factor.
Authorization	The rules that determine what an authenticated person or system is allowed to do.
Brute-force attack	Repeatedly trying many possible passwords or keys. This can lock accounts or disrupt systems and requires explicit authorization.
Chain of custody	A documented record of who collected, handled, transferred, and examined digital evidence.
Checksum	A calculated value used to check whether a downloaded file changed or became corrupted.

Term	Entry-level meaning
Command-line interface (CLI)	A text-based way to control a computer by entering commands.
Common Vulnerabilities and Exposures (CVE)	A public identifier assigned to a known cybersecurity vulnerability.
Credential	Information used to prove identity, such as a username, password, API key, certificate, or token.
Digital evidence	Data that may help explain an event, incident, or activity and must be handled carefully.
Enumeration	Collecting detailed information about systems, accounts, shares, services, or applications after initial discovery.
Exploit	Code or a technique that uses a vulnerability to cause an unintended result.
False positive	A result that appears to identify a problem but is incorrect after validation.
Forensic image	A bit-for-bit copy of storage media created for examination while preserving the original.
Hash	A calculated digital fingerprint used to identify data, verify integrity, or support password auditing.
Host	A computer, server, phone, virtual machine, or other device connected to a network.
HTTP proxy	A tool that sits between a browser and a web application so requests and responses can be inspected.
Incident response	The organized process of preparing for, detecting, investigating, containing, and recovering from security incidents.
IP address	A numerical address used to identify and communicate with a device on a network.
Jailbreak	An attempt to make an AI system ignore its intended rules or safeguards.
Least privilege	Giving users and systems only the minimum access needed to perform their tasks.
Log	A record of events generated by an operating system, application, network device, or security tool.
Malware	Software designed to disrupt, damage, spy on, or gain unauthorized access to systems or data.
Network service	A program that listens for connections and provides a function such as web, email, file sharing, or remote access.
Open-source intelligence (OSINT)	Information collected lawfully from publicly available sources.
Packet	A small unit of data transmitted across a network.
Payload	The action or code delivered after a vulnerability is used.
Penetration test	An authorized, scoped assessment that safely attempts to identify and validate security weaknesses.
Port	A numbered logical endpoint used by network services.
Privilege escalation	Gaining permissions beyond those assigned to the current user or process.
Prompt injection	Instructions placed in input or retrieved content that try to manipulate an AI system into ignoring its intended rules.
RAG	Retrieval-augmented generation: a method that supplies retrieved information to a language model before it answers.
Reconnaissance	The early process of gathering information about an authorized target.
Responsible disclosure	Privately reporting a security weakness to the affected organization and allowing reasonable time for correction.
Risk	The possibility that a threat will exploit a weakness and cause harm, considered together with likelihood and impact.
Scope	The approved boundaries of a security activity, including targets, dates, accounts, and permitted techniques.

Term	Entry-level meaning
Service	A program that offers a network or system function.
Shell	A command environment used to interact with an operating system.
Snapshot	A saved state of a virtual machine that can be restored after a mistake or failed change.
Social engineering	Manipulating people into revealing information or taking unsafe actions.
Threat	A person, event, action, or condition capable of causing harm.
Token	A value used to represent identity, authorization, or a session. Tokens must be protected like passwords.
Virtual machine (VM)	A software-based computer that runs inside a physical host computer.
VPN	A virtual private network that creates an encrypted connection to another network or lab environment.
Vulnerability	A weakness that may be exploited or otherwise create risk.
Wordlist	A file containing words or possible values used by authorized discovery or password-auditing tools.
Write blocker	A hardware or software control used to reduce the chance of modifying original evidence media.
Zero-day vulnerability	A vulnerability that is newly discovered and may not yet have an available fix.

This manual prefers primary and official sources. Tool behavior, packages, screenshots, and platform rules can change. Follow the links below and verify current instructions before acting.

[Kali Linux](#)

[Get Kali](#)

[Kali documentation](#)

[Kali tool documentation](#)

[Kali virtualization documentation](#)

[Hack The Box](#)

[HTB Starting Point](#)

[HTB Academy](#)

[HTB Getting Started](#)

[OWASP](#)

[NIST Cybersecurity](#)

[MITRE ATT&CK](#)

[MITRE ATLAS](#)

[Creative Commons license](#)

This is a living educational project. Readers are encouraged to report broken links, unclear explanations, grammar problems, accessibility concerns, and technical errors. Do not submit credentials, flags, active-machine solutions, personal information, client data, or unverified exploit claims.

Planned GitHub repository structure

```
kali-learning-manual/  
├── README.md  
├── LICENSE  
├── CODE_OF_CONDUCT.md  
├── CONTRIBUTING.md  
├── CHANGELOG.md  
├── docs/en/  
├── docs/es/  
├── docs/pt-br/  
├── companion-guides/  
├── assets/  
└── references/
```

The public repository link will be added to the next revision after the repository is created. The source edition will be maintained in English, with properly localized Latin American Spanish and Brazilian Portuguese editions.

Keep learning. Stay curious. Use your skills to protect people.

Every experienced cybersecurity professional was once a beginner.

First Public Edition - English Master - July 2026

Free for noncommercial educational sharing under CC BY-NC-SA 4.0